

Abdul Wahid
EC-Council CND (Certified Network Defender)

Perimeter Network Security – pfSense, IDS & Defense-in-Depth Validation

Executive Summary

Module 4 completes the three-part cybersecurity lab series by adding perimeter network security to the environment built in Modules 2 and 3. pfSense is deployed as the edge firewall and default gateway for all virtual machines, replacing previously unconfigured gateways and ensuring all network traffic is subject to centrally enforced firewall rules.

Key firewall rules are configured to block ICMP and RDP from the client workstation to the domain controller, while explicitly permitting essential Active Directory services. Suricata on IDS01 is updated with new detection rules covering SQL injection, XSS, brute force, and LLMNR poisoning. The SoftEther VPN on VPN01 is validated to continue functioning correctly through the new gateway.

A full eight-scenario attack simulation is run from ATTACK01 to confirm every control is working — firewall rules block restricted traffic, the IDS detects application-layer attacks, account lockout stops brute force attempts, and LLMNR poisoning fails due to the GPO applied in Module 3.

Together, Modules 2, 3, and 4 deliver a practical, fully operational defence-in-depth architecture spanning administrative hardening, host-based controls, and perimeter security.

Contents

Introduction 5

VMware Workstation Preparation 5

Configure virtual networks 5

pfSense (Edge Firewall / Router) 7

Start the Pfsense Virtual Machine 7

Access the pfSense Web UI 9

Run the pfSense Setup Wizard 10

UPDATE ALL EXISTING VMs TO USE pfSense AS GATEWAY 13

Update Gateway on ADMIN01 13

Update Gateway on DC01 15

Update Gateway on CL01 15

Update Gateway on VPN01 16

Update Gateway on IDS01 (Kali Linux) 16

Update Gateway on ATTACK01 (Kali Linux) 17

Verify Connectivity After Gateway Update 17

CONFIGURE FIREWALL RULES ON pfSense 18

Rule 1 — Block ICMP (ping) from CL01 19

Rule 2 — Block RDP from CL01 to DC01 21

Rule 3 — Allow AD Services from Internal Network to DC01 22

Enable Logging on All Rules 23

Test Your Firewall Rules 24

VERIFY ACTIVE DIRECTORY IS STILL CORRECT 26

Check AD OUs and Users on DC01 26

Check Group Memberships 27

Force GPO Update on All Windows VMs 28

VERIFY GPOs STILL APPLY AFTER GATEWAY CHANGE 28

Check GPO is Applying on CL01 28

Verify SMBv1 Still Disabled (on DC01) 29

Verify Account Lockout Policy Still Active (on DC01) 29
Verify TLS 1.0 is Still Disabled (on DC01).....29
Verify LLMNR is Still Disabled (on DC01).....29
UPDATE SURICATA RULES ON IDS01.....30
Open the Rules File.....30
Add SQL Injection Detection Rules.....30
Add XSS Detection Rules 30
Add Brute Force Detection Rules.....31
Add LLMNR / NBT-NS Poisoning Detection Rules.....31
Save, Test, and Restart Suricata 32
VERIFY VPN01 STILL WORKS WITH pfSense GATEWAY 33
Add pfSense Pass Rule for VPN Client Traffic 33
Confirm SoftEther VPN is Still Running on VPN01 35
Test VPN Connection from ATTACK01 36
ATTACK SIMULATION (All from ATTACK01) 38
Attack 1 — Network Reconnaissance 39
Attack 2 — SMBv1 / EternalBlue Check (Verification) 40
Attack 3 — Brute Force Attack 41
Attack 4 — LLMNR Poisoning Test 43
Attack 5 — SQL Injection Test 45
Attack 6 — XSS Test.....46
Attack 7 — VPN Access Validation.....47
Attack 8 — TLS Version Verification 50
MONITORING AND LOGGING-VERIFICATION 52
Verify Sysmon is Running.....52
Check Windows Admin Center 53
View pfSense Logs During Attacks.....56
View IDS Logs.....56
Conclusion.....58

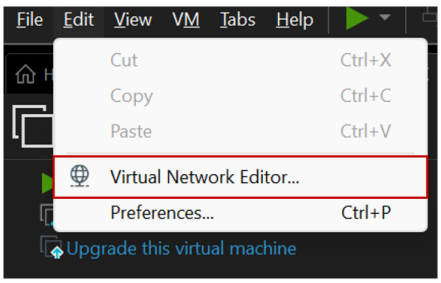
Introduction

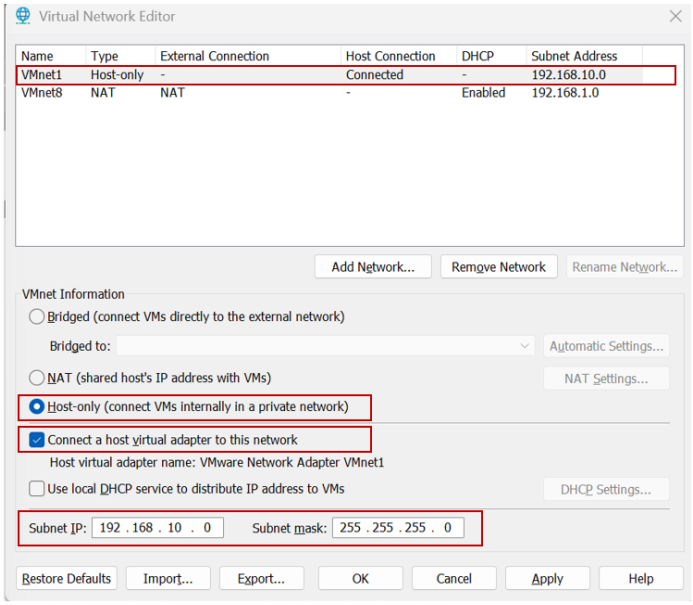
Module 4 extends the lab built in Modules 2 and 3 by adding perimeter network security. pfSense is deployed as the network gateway and edge firewall, replacing the blank default gateway on all existing VMs. Firewall rules are configured to enforce traffic policies across the internal network, Suricata on IDS01 is updated with new detection rules for SQL injection, XSS, brute force, and LLMNR poisoning, and a full attack simulation is run to validate every control is working correctly.

VMware Workstation Preparation

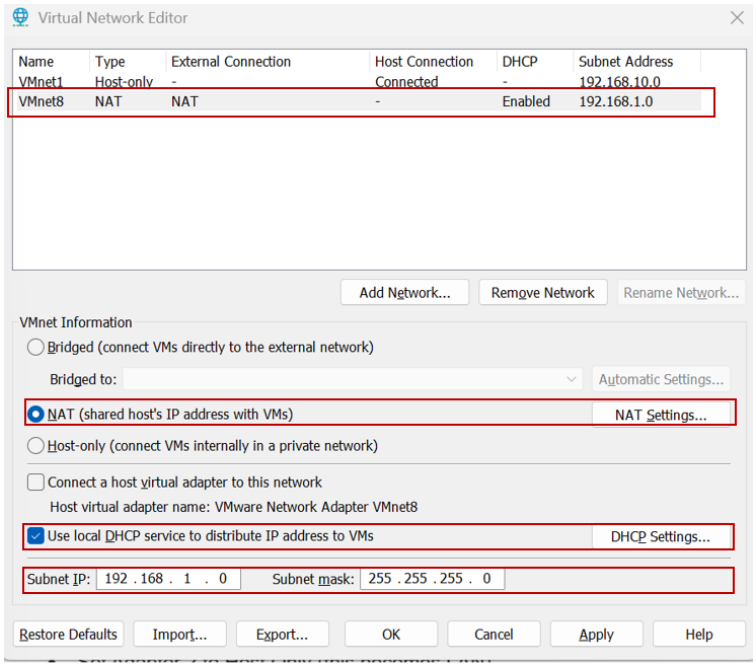
Configure virtual networks

Open VMware Workstation → Edit → Virtual Network Editor (run as Administrator).





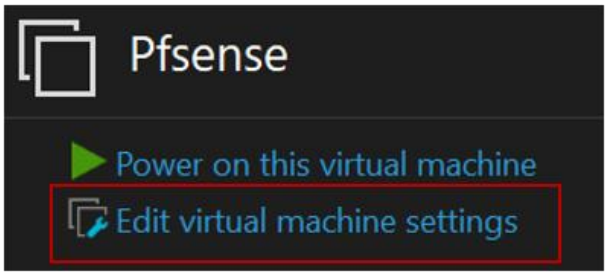
VMnet1 → set to Host-Only, subnet 192.168.10.0, mask 255.255.255.0, disable DHCP (you'll assign static IPs manually on each VM).

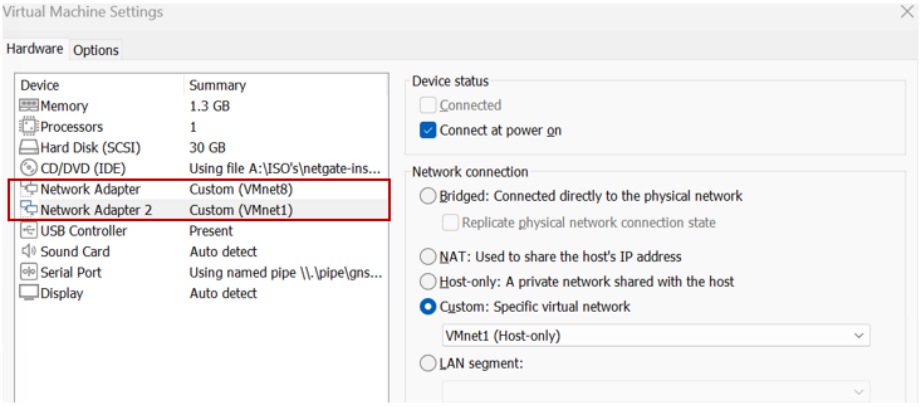


VMnet8 → leave as NAT (192.168.1.0). This gives pfSense, Smooth wall, and VPN01 their WAN internet access.

pfSense (Edge Firewall / Router)

Go to pfsense Virtual Machine settings.





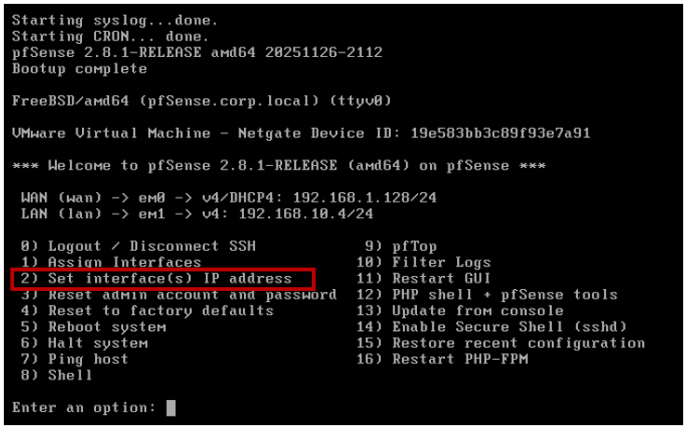
Set Adapter 1 to NAT (this becomes WAN)

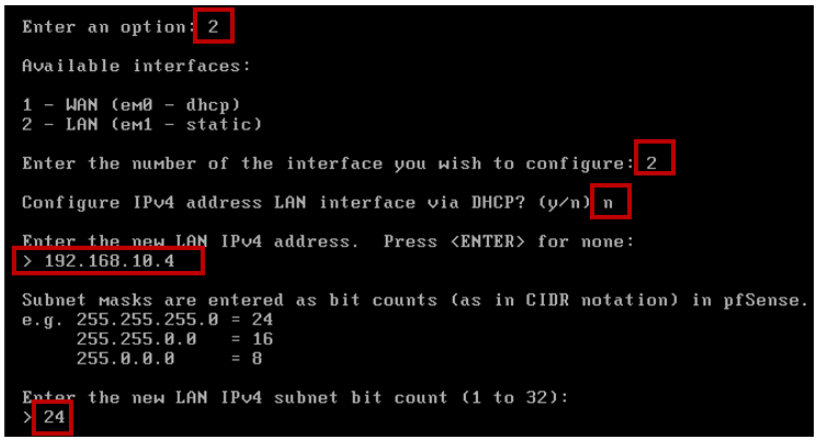
Set Adapter 2 to Host Only (this becomes LAN)

In our previous labs, we had setup pfsense rules so that WAN network would be able to connect inside the LAN. We will delete all those rules and create new ones.

Start the Pfsense Virtual Machine

Press 2 to setup interfaces IP address



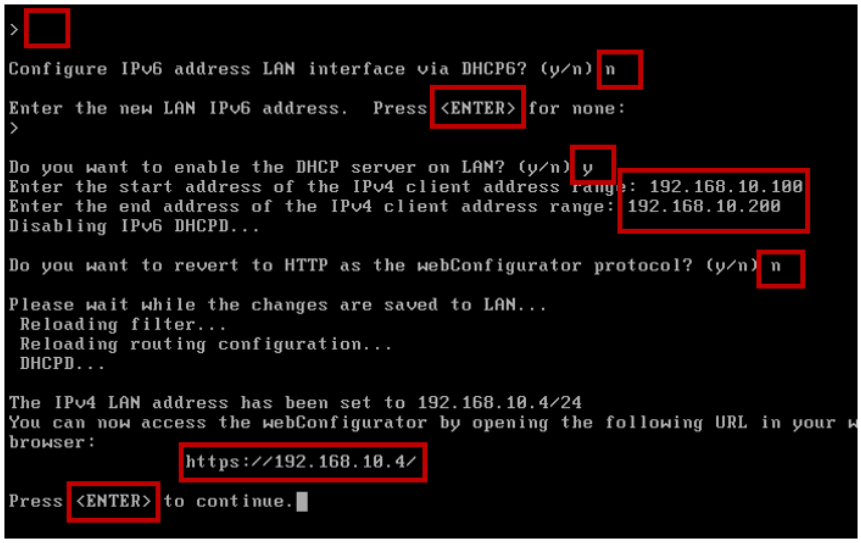


Set LAN IP address

Enter 'n'

Enter the LAN IP address manually

Enter the Subnet Mask: 24



Press Enter for none (No need for the IPv4 upstream Gateway)

Configure IPv6: Press 'n'

Press Enter for None (IPv6 setup)

Enable the DHCP Server: 'y'

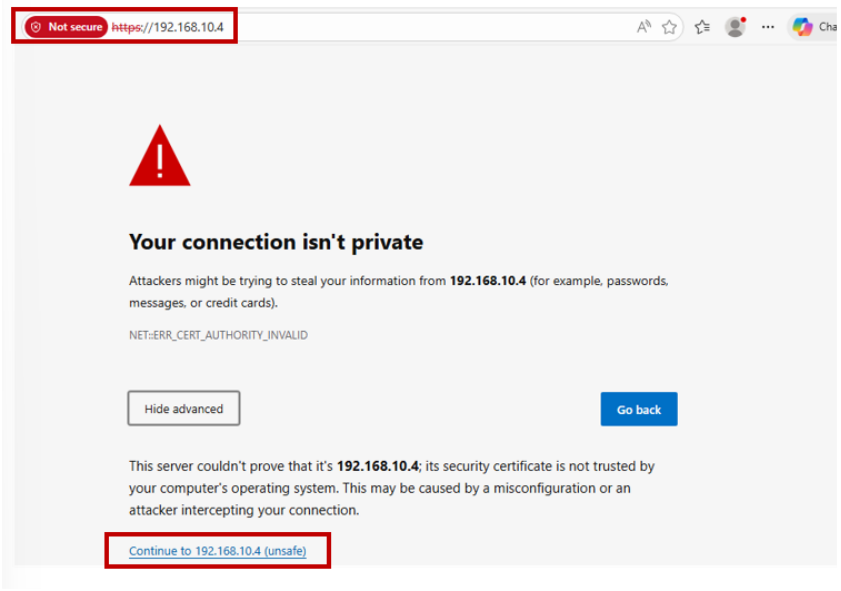
Enter the Range for DHCP Server

Press 'n' for not reverting to HTTP

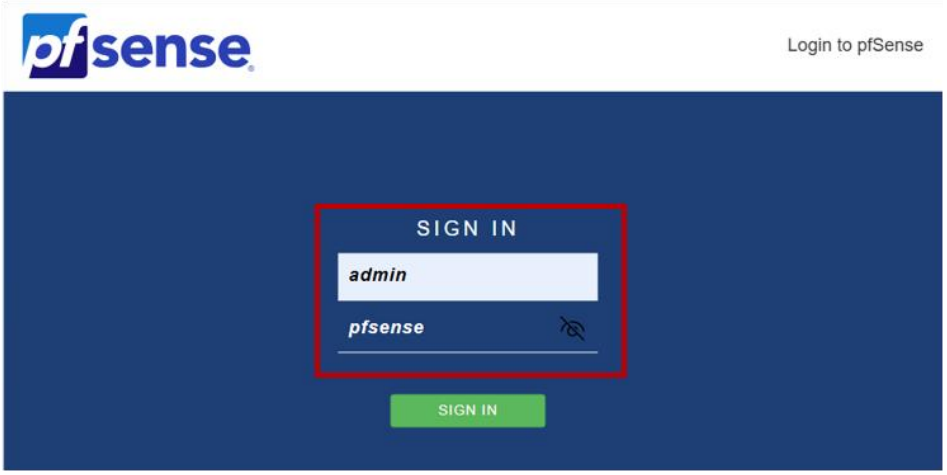
Press Enter for Continue

Access the pfSense Web UI

Turn on your ADMIN01 Virtual Machine and search for Pfsense LAN IP

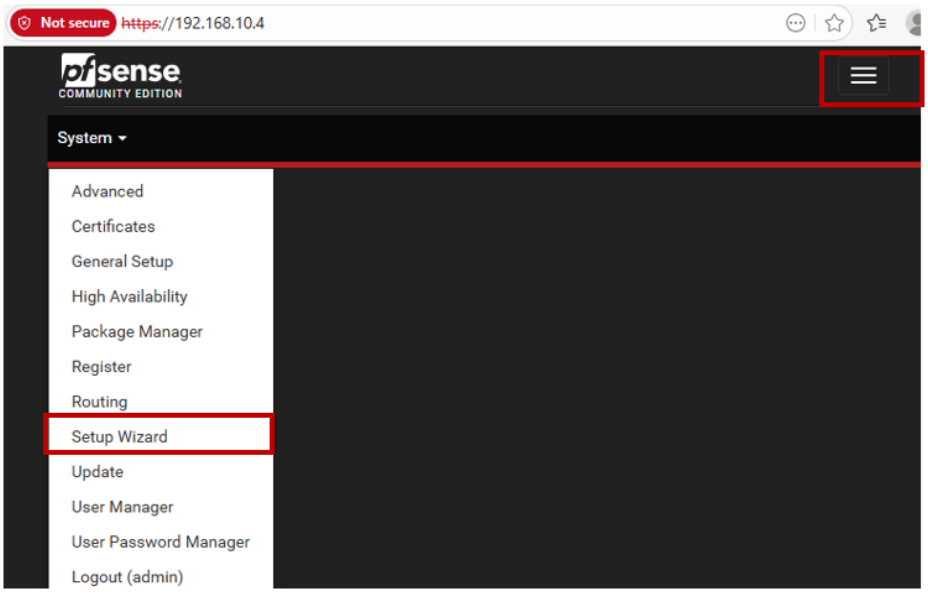


Enter the Username and Password and click SIGN IN

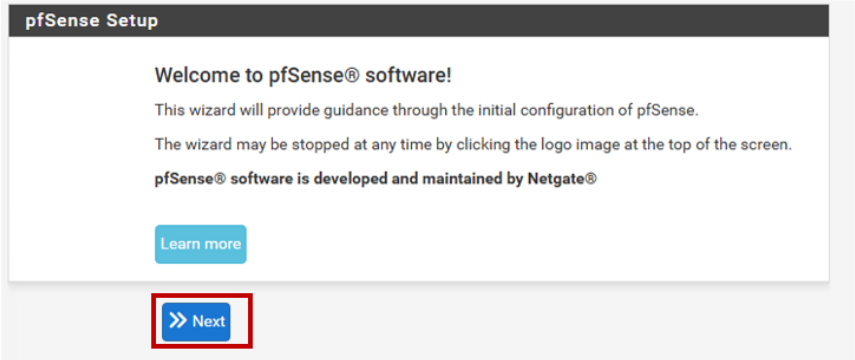


Run the pfSense Setup Wizard

Go to System → Setup Wizard

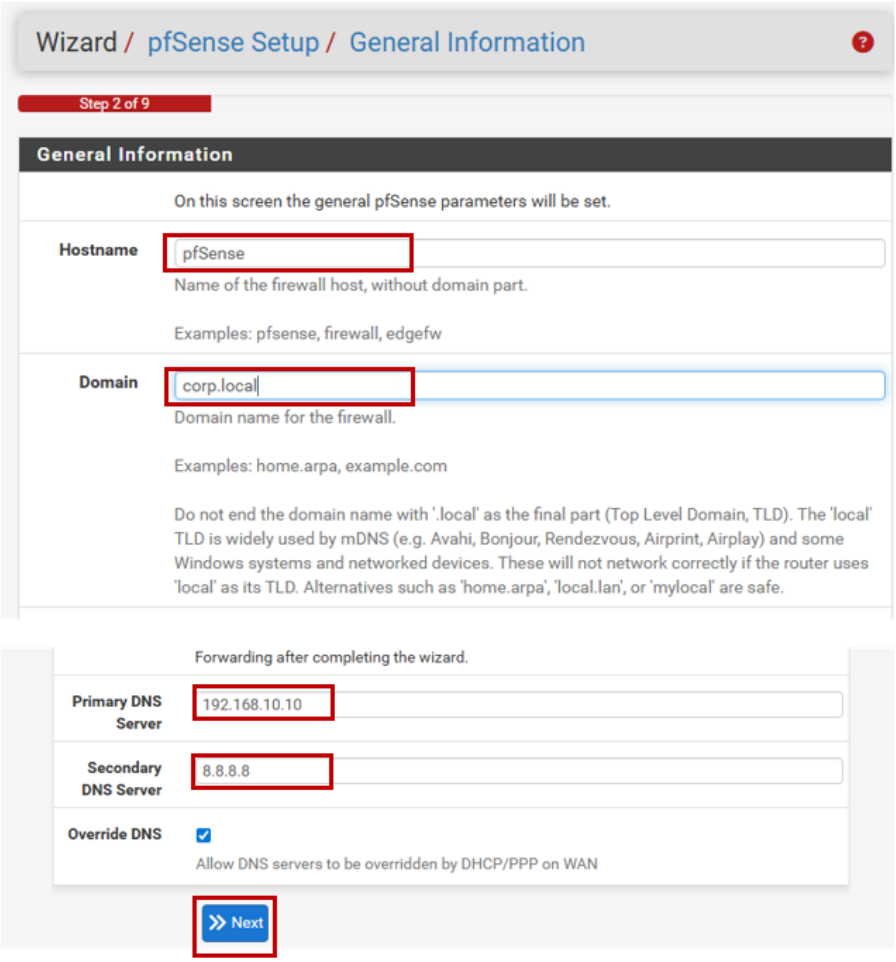


Click Next

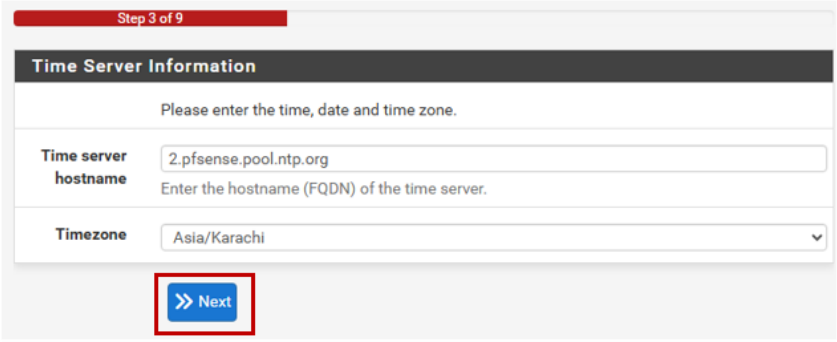


Set the Domain Name to which you setup in Module 2 and 3

Set the Primary DNS Server to the IP address of the DC01 and click Next

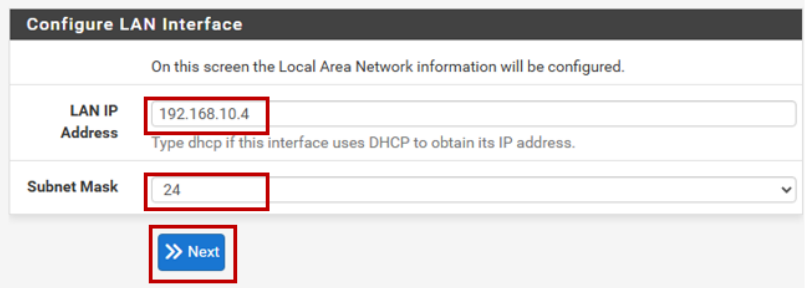


Time zone: select your correct time zone → click Next

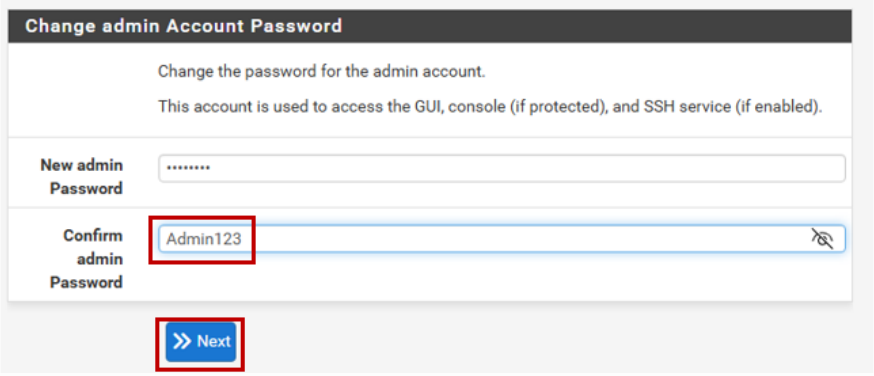


Leave the WAN configuration as it is and click Next

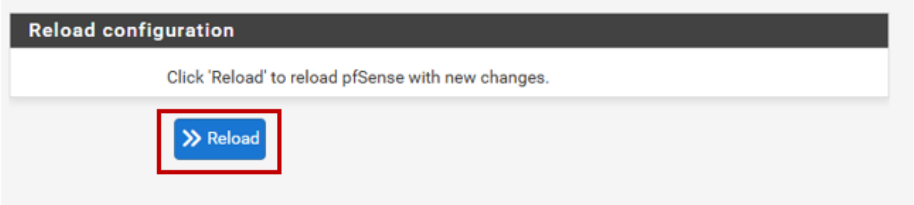
We had already setup the LAN IP address, just confirm if the IP entered is correct and then click Next



Admin Password: change it from *pfsense* to something you will remember, for example **Admin123** → click Next



Click **Reload** → wait for pfSense to apply → click **Finish**





You are now on the pfSense dashboard. You can see the WAN IP (from NAT) and LAN IP 192.168.10.4.

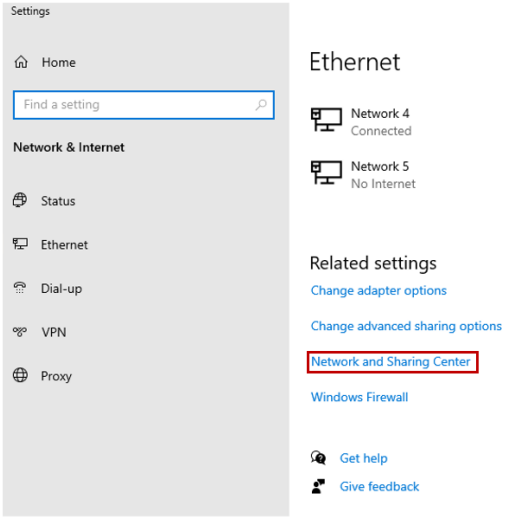
UPDATE ALL EXISTING VMs TO USE pfSense AS GATEWAY

This is the single most important step in Module 4. Now that pfSense is the router, every VM must point to **192.168.10.4** as its default gateway. Without this, traffic will not route through pfSense, and your firewall rules will not work.

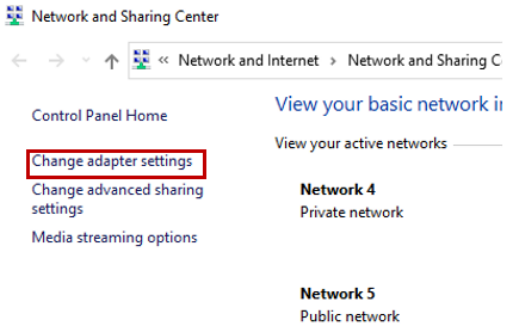
Update Gateway on ADMIN01

Log in to **ADMIN01** as CORP\Administrator

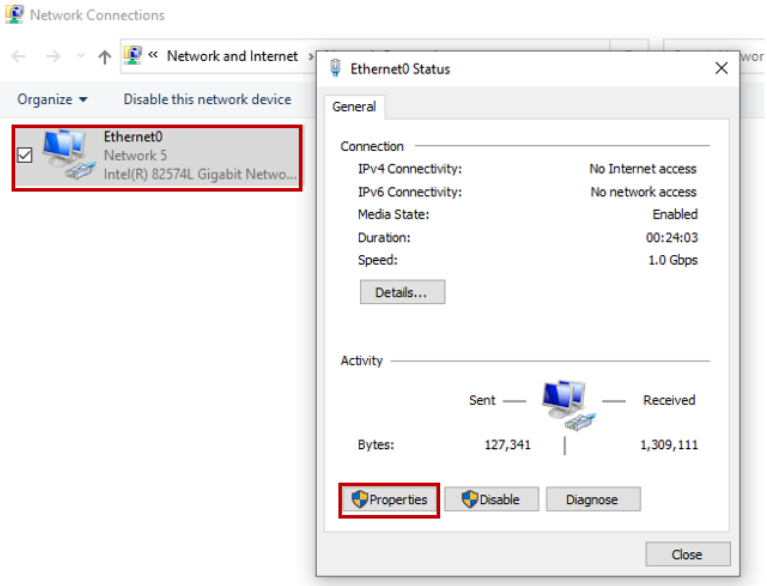
Go to Adapter Settings and click on Network and Sharing Center



Select Change adapter settings

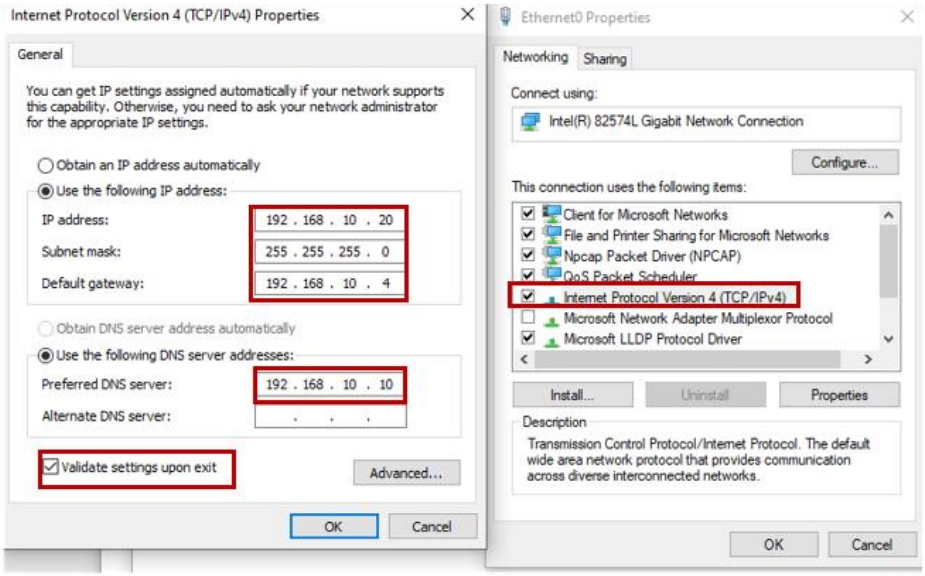


Right-click **Ethernet** (the Host-Only adapter) → click **Properties**



Double-click **Internet Protocol Version 4 (TCP/IPv4)**

Change **Default gateway** to **192.168.10.4**



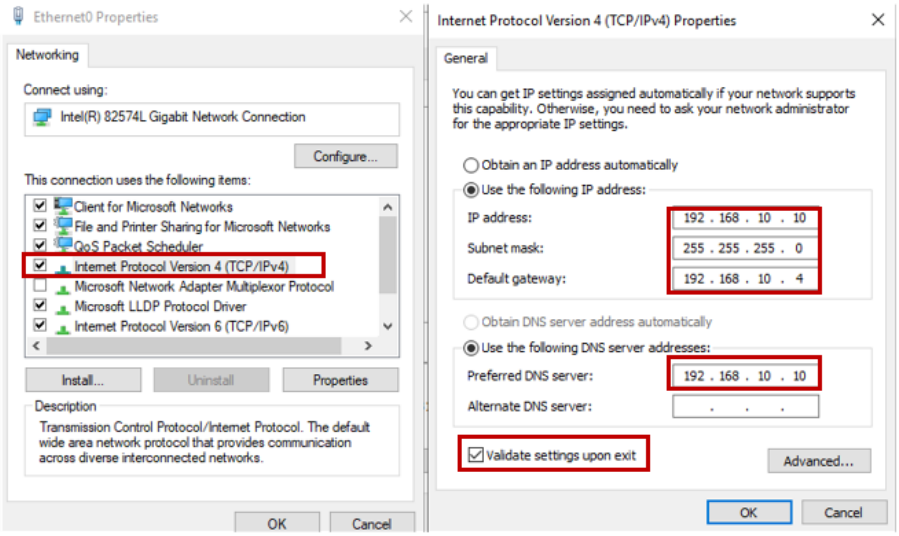
Leave everything else as is IP stays 192.168.10.20, Subnet mask stays 255.255.255.0, DNS stays 192.168.10.10

Update Gateway on DC01

Go to adapter settings

Right-click **Ethernet** → **Properties** → double-click **IPv4**

Set **Default gateway**: **192.168.10.4**



Leave everything else: IP stays 192.168.10.10, DNS stays 192.168.10.10

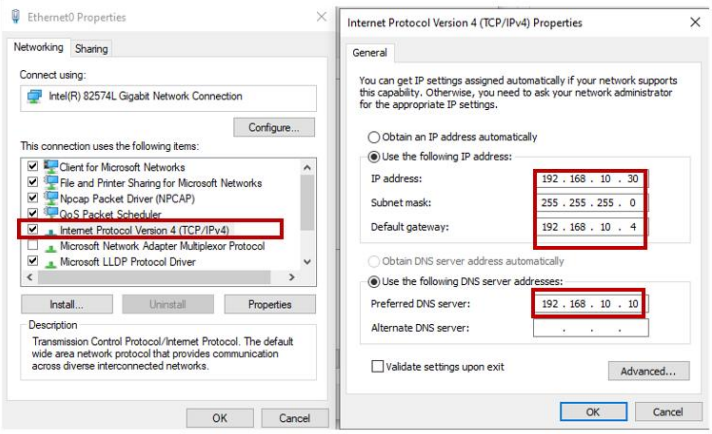
Click **OK** → **OK** → **Close**

Update Gateway on CL01

Log in to **CL01**

Same steps as above

Set **Default gateway**: **192.168.10.4**



IP stays 192.168.10.30, DNS stays 192.168.10.10

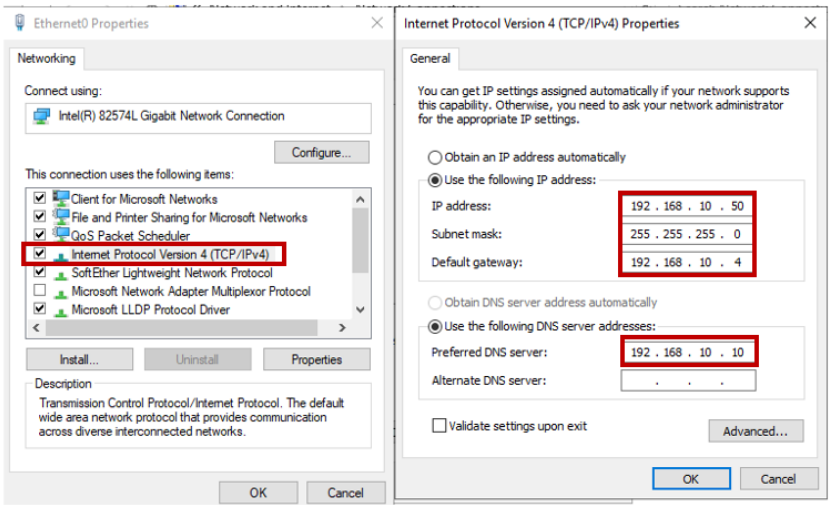
Click **OK** → **OK** → **Close**

Update Gateway on VPN01

Log in to **VPN01** as CORP\Administrator

Same steps

Set **Default gateway**: **192.168.10.4**



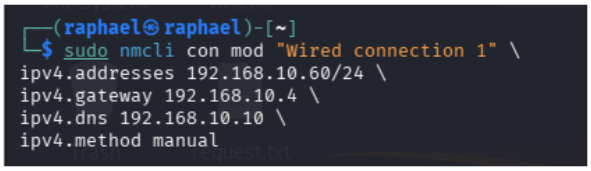
IP stays 192.168.10.50, DNS stays 192.168.10.10

Click **OK → OK → Close**

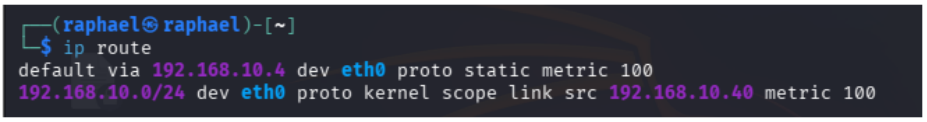
Update Gateway on IDS01 (Kali Linux)

Open a terminal on IDS01 and run:

```
sudo nmcli con mod "Wired connection 1" \
ipv4.addresses 192.168.10.60/24 \
ipv4.gateway 192.168.10.4 \
ipv4.dns 192.168.10.10 \
ipv4.method manual
sudo nmcli con up "Wired connection 1"
```



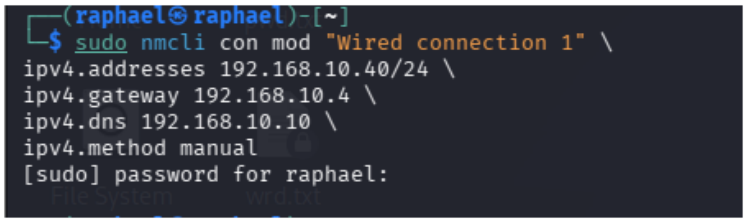
You should see a line that says: **default via 192.168.10.4 dev eth0**



Update Gateway on ATTACK01 (Kali Linux)

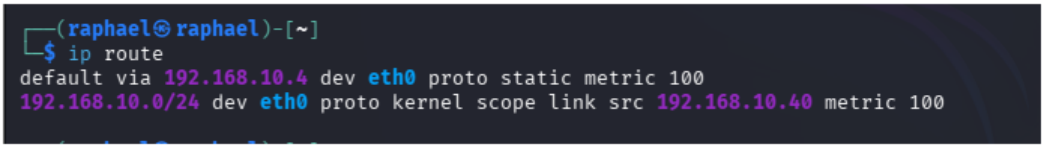
Same as IDS01. Open a terminal:

```
sudo nmcli con mod "Wired connection 1" \
ipv4.addresses 192.168.10.40/24 \
ipv4.gateway 192.168.10.4 \
ipv4.dns 192.168.10.10 \
ipv4.method manual
sudo nmcli con up "Wired connection 1"
```





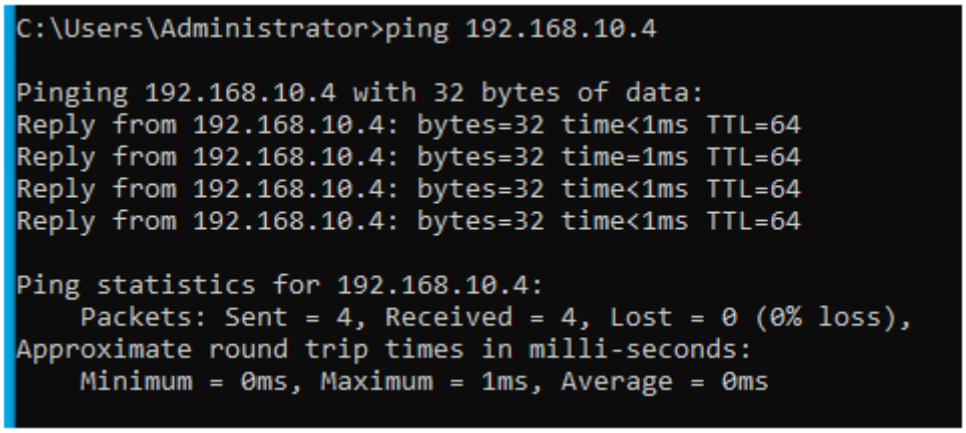
Again, you should see **default via 192.168.10.4 dev eth0**



Verify Connectivity After Gateway Update

On ADMIN01 open Command Prompt and run:

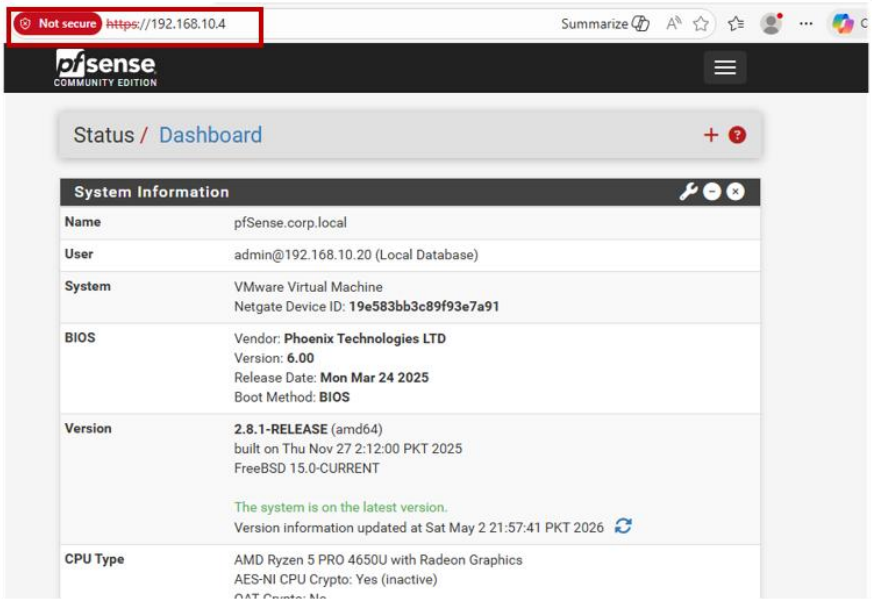
```
ping 192.168.10.4
```



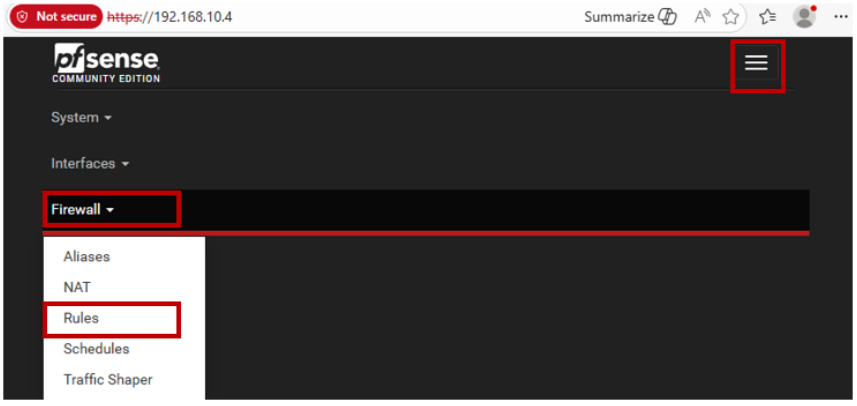
You should get replies from pfSense. If you do, the gateway update is working correctly on ADMIN01. Repeat a ping test from each VM to confirm.

CONFIGURE FIREWALL RULES ON pfSense

All of this is done in the pfSense web UI from ADMIN01's browser at **https://192.168.10.4**

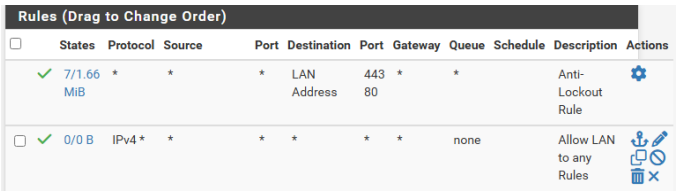


Go to **Firewall → Rules → LAN tab**.



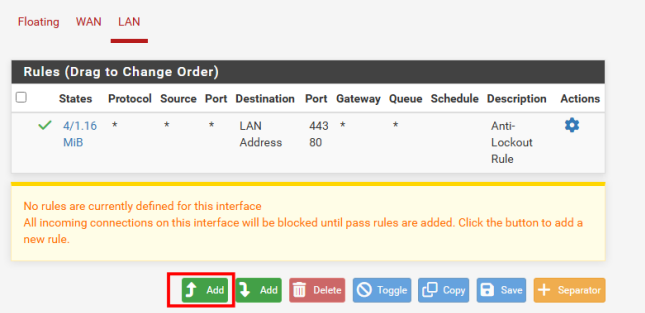
Important: pfSense processes rules top to bottom. Block rules must be placed ABOVE allow rules for the same traffic. Use the up-arrow Add button to add a rule to the TOP of the list, and the down-arrow Add button to add to the BOTTOM.

Delete all the existing rules except the Allow LAN to all rules if you are using Pfsense configured from previous labs



Rule 1 — Block ICMP (ping) from CL01

Click **Add** (up-arrow — adds to top)



Action: **Block**

Interface: **LAN**

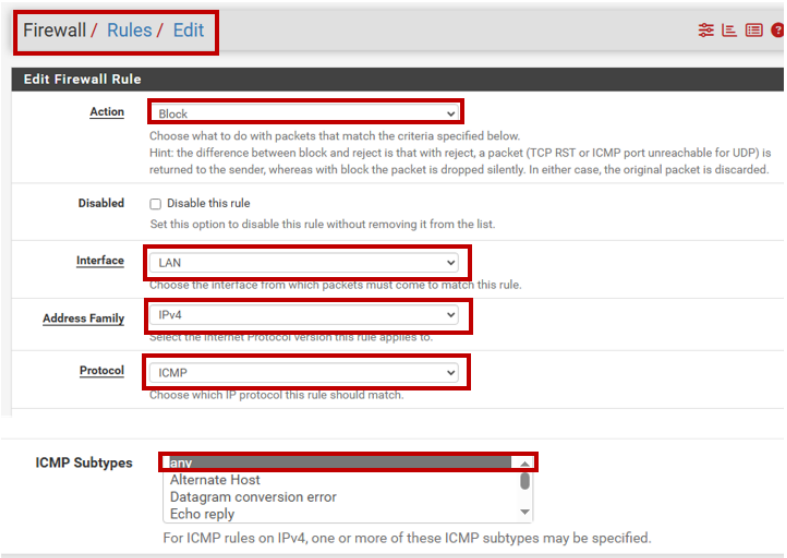
Address Family: **IPv4**

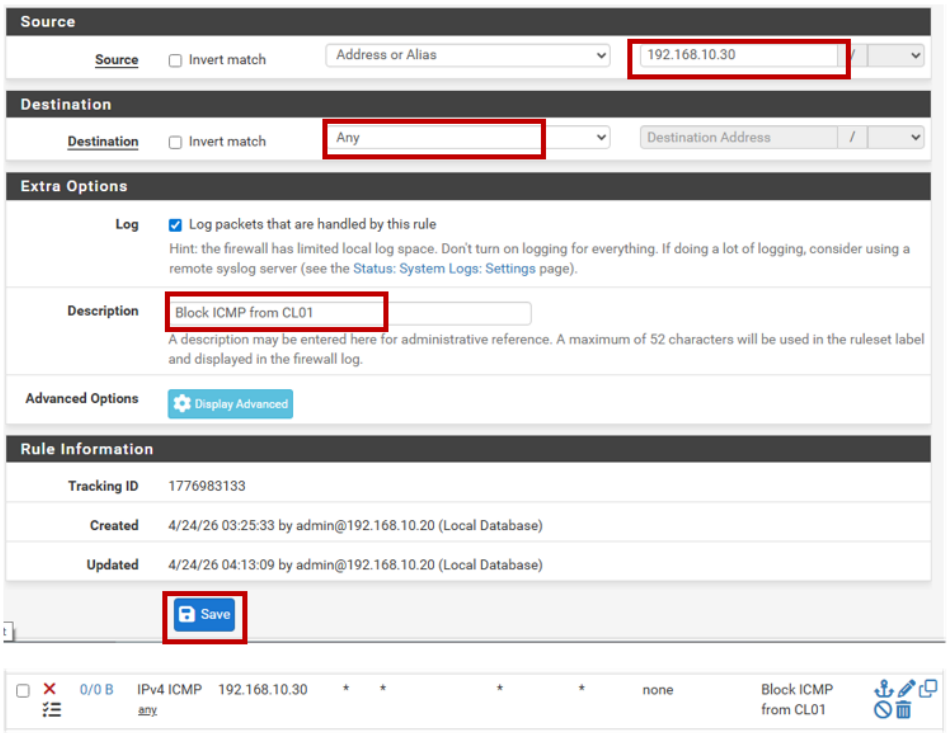
Protocol: **ICMP**

ICMP Type: **any**

Source: **Single host or alias** → type **192.168.10.30**

Destination: **any**





Description: **Block-ICMP-From-CL01**

Click **Save** → click **Apply Changes** (the green option at the top)

Now confirm by trying to ping from CL01 to 8.8.8.8

```
C:\Users\Administrator>ping 8.8.8.8

Pinging 8.8.8.8 with 32 bytes of data:
Request timed out.
Request timed out.
Request timed out.
Request timed out.

Ping statistics for 8.8.8.8:
    Packets: Sent = 4, Received = 0, Lost = 4 (100% loss),
```

Rule 2 — Block RDP from CL01 to DC01

Click **Add** (up-arrow — adds to top, above the ICMP rule)

Action: **Block**

Interface: **LAN**

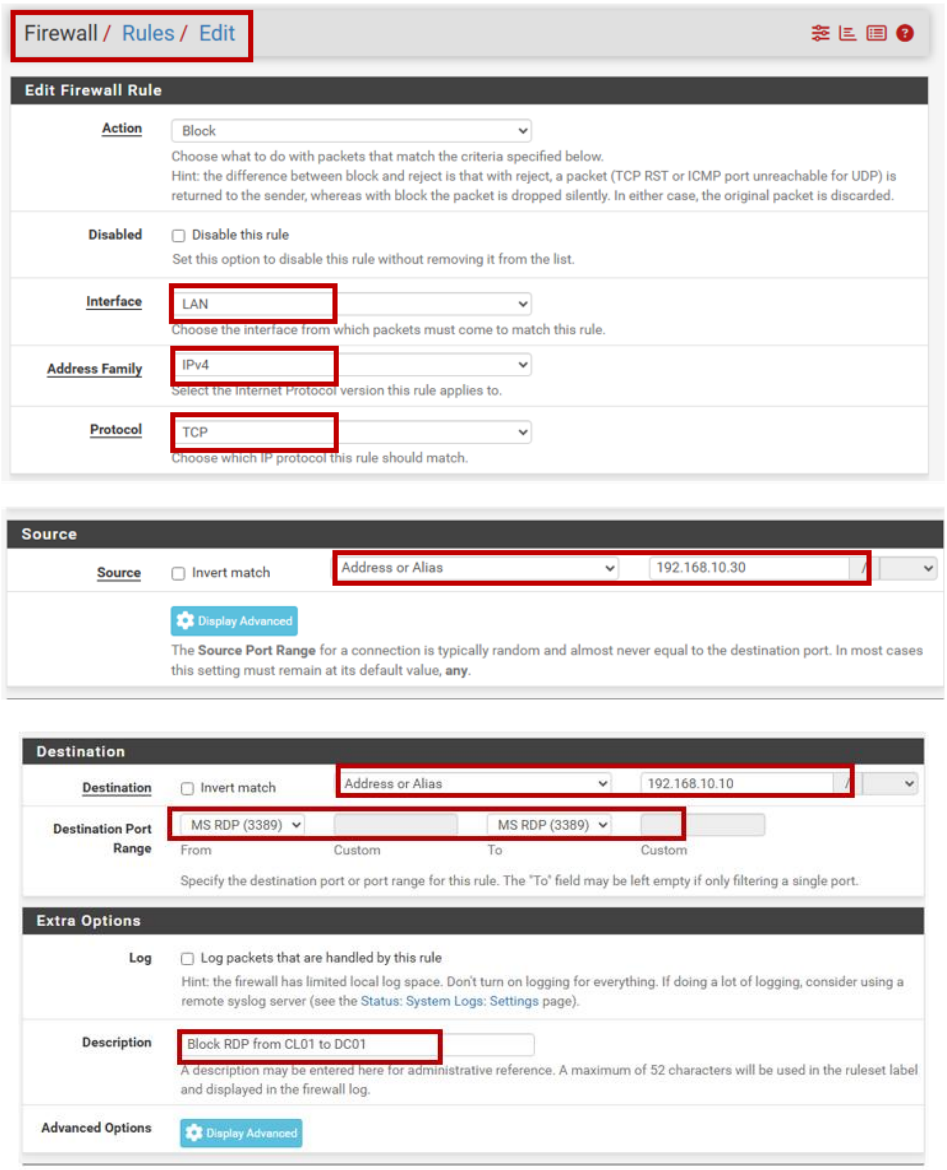
Address Family: **IPv4**

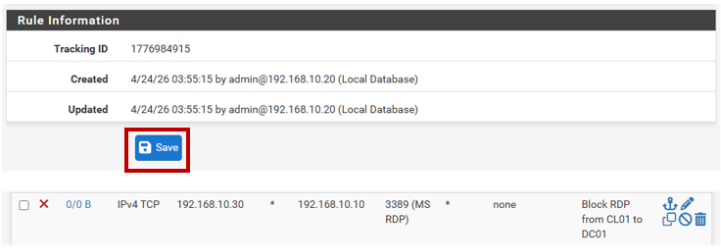
Protocol: **TCP**

Source: **Single host → 192.168.10.30**

Destination: **Single host → 192.168.10.10**

Destination Port Range: from dropdown select **RDP (3389)** for both From and To fields





Description: **Block-RDP-CL01-to-DC01**

Click **Save** → **Apply Changes**

Rule 3 — Allow AD Services from Internal Network to DC01

You need to add one Pass rule for each Active Directory port. For each one below:

Click **Add** (down-arrow — adds to BOTTOM, after the block rules), then:

Action: **Pass**

Interface: **LAN**

Address Family: **IPv4**

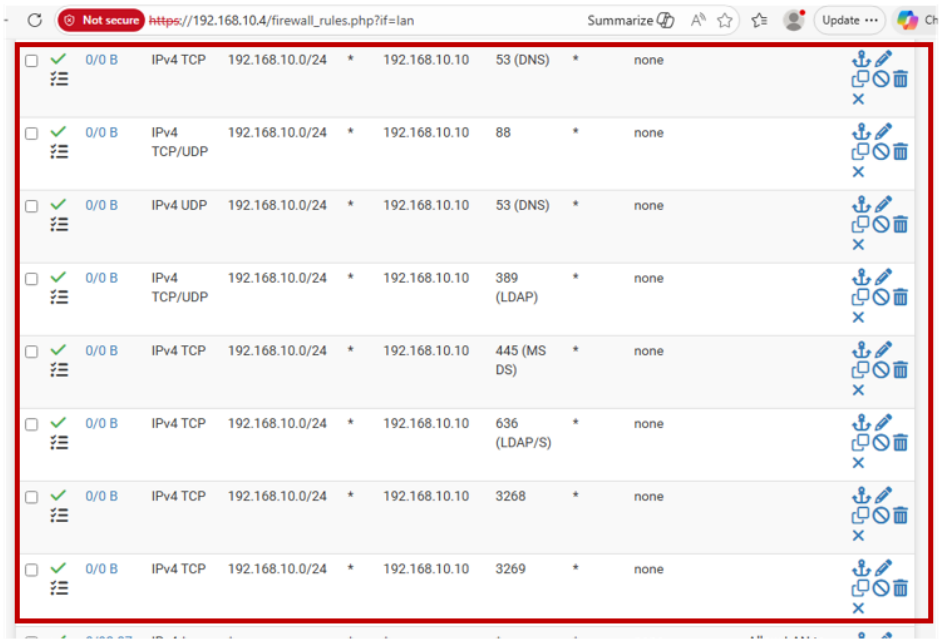
Source: **Network** → **192.168.10.0 / 24**

Destination: **Single host** → **192.168.10.10**

Add one rule for each of these ports:

Port	Protocol	Description to use
53	TCP	Allow-DNS-TCP-to-DC01
53	UDP	Allow-DNS-UDP-to-DC01
88	TCP/UDP	Allow-Kerberos-to-DC01
389	TCP/UDP	Allow-LDAP-to-DC01
445	TCP	Allow-SMB-to-DC01
636	TCP	Allow-LDAPS-to-DC01
3268	TCP	Allow-GlobalCatalog-to-DC01
3269	TCP	Allow-GlobalCatalogSSL-to-DC01

For the Destination Port Range field: select **Other** and type the port number in both the From and To boxes.



After adding all rules click **Save** then **Apply Changes**.

Enable Logging on All Rules

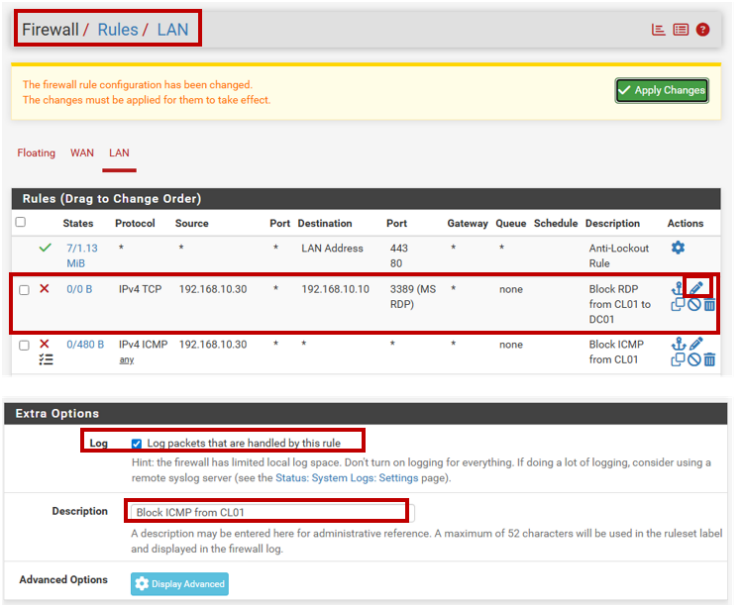
Go to **Firewall → Rules → LAN**

Click the pencil (edit) icon next to **Block-ICMP-From-CL01**

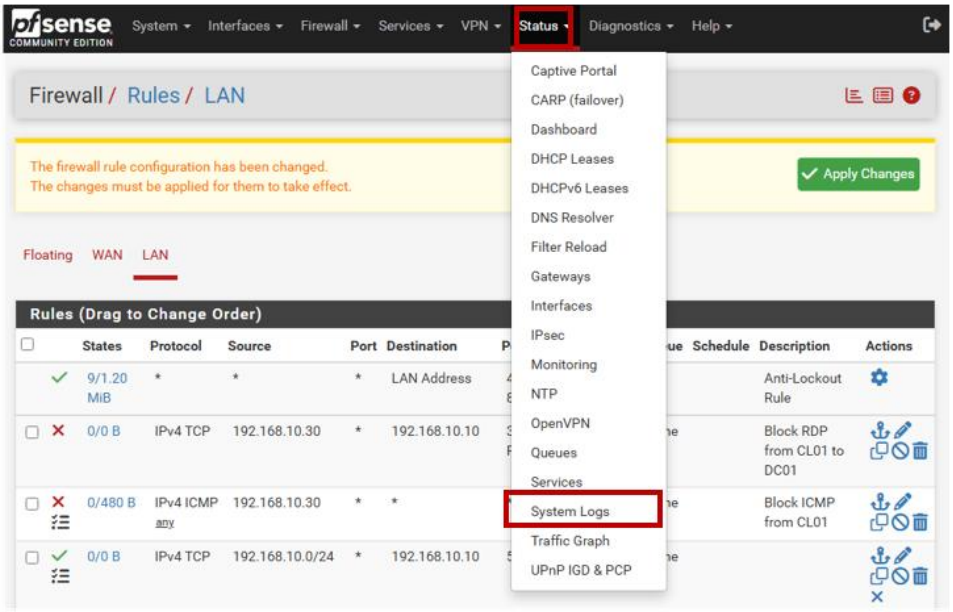
Scroll down and check the box: **Log packets that are handled by this rule**

Click **Save → Apply Changes**

Repeat this for every rule you created — edit each one and enable logging



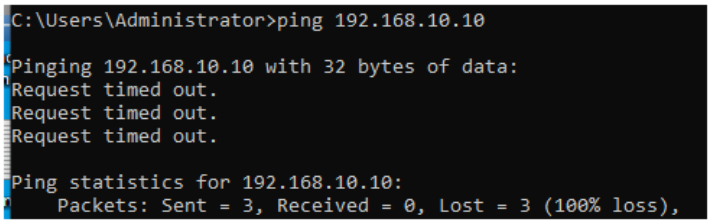
To view logs: go to **Status → System Logs → Firewall tab**.



You will see real-time entries showing time, interface, action (block/pass), source IP, destination IP, and port.

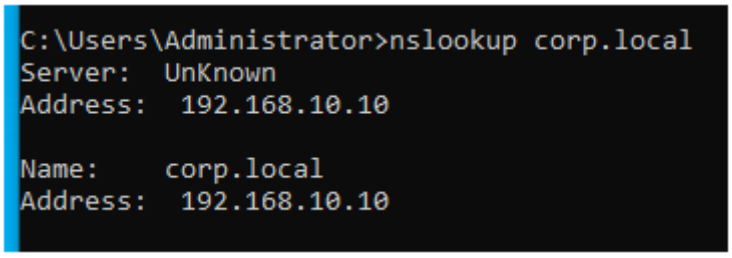
Test Your Firewall Rules

Test 1 — CL01 cannot ping DC01: On CL01, open Command Prompt and run: ping 192.168.10.10



Expected result: Request timed out — Block ICMP rule is working.

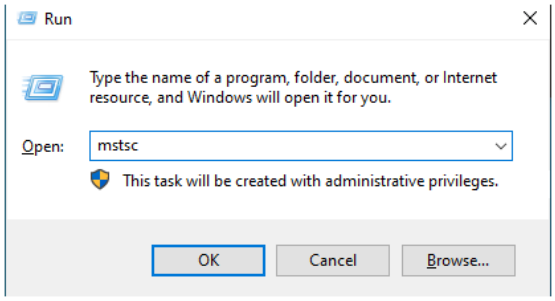
Test 2 — CL01 can still resolve DNS: On CL01 Command Prompt run: nslookup corp.local



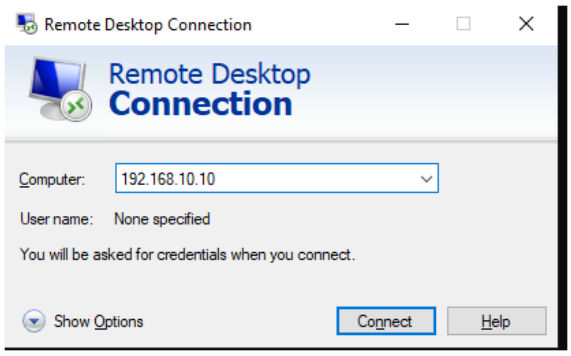
Expected result: Returns 192.168.10.10 — DNS port 53 is allowed through.

Test 3 — CL01 cannot RDP to DC01:

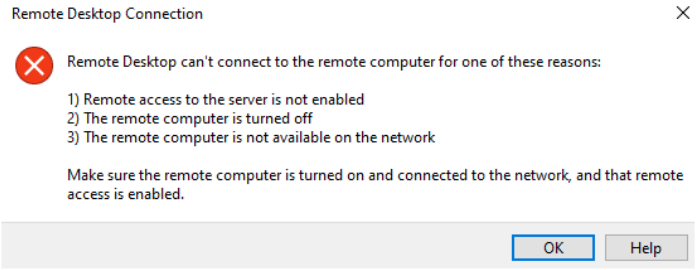
On CL01 press Win+R → type mstsc



Enter → Computer: 192.168.10.10



Connect Expected result: Connection fails — Block RDP rule is working.

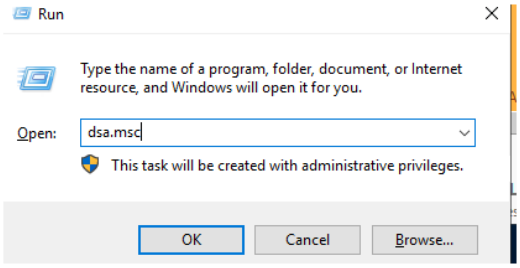


VERIFY ACTIVE DIRECTORY IS STILL CORRECT

After adding pfSense as the gateway, confirm your AD structure from Modules 2 and 3 is still intact.

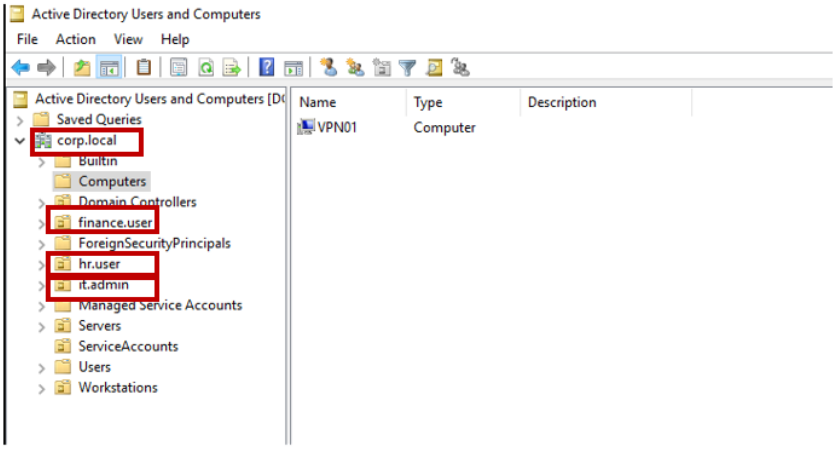
Check AD OUs and Users on DC01

On DC01, press **Win+R** → type **dsa.msc** → press Enter



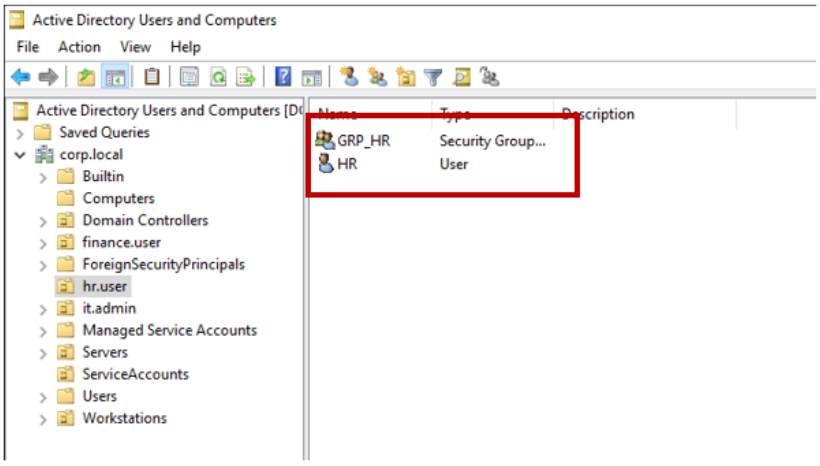
Expand **corp.local** in the left panel

Confirm these OUs exist: **IT, HR, Finance, Workstations, Servers, ServiceAccounts**

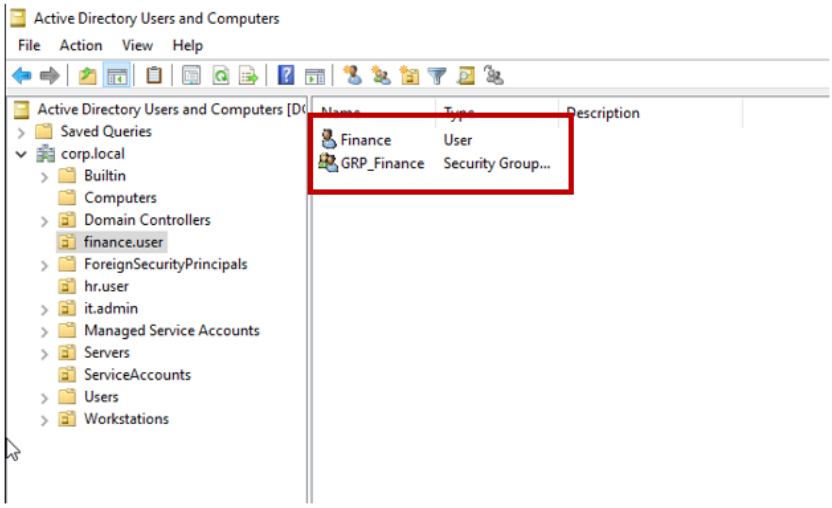


Check Group Memberships

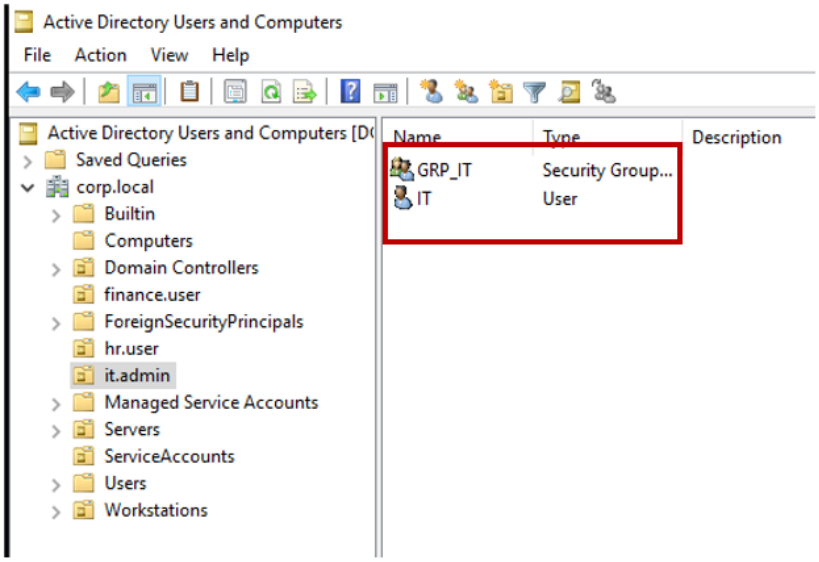
Double-click **GRP_HR** → Members tab → confirm **hr.user** is listed



Double-click **GRP_Finance** → confirm **finance.user** is listed



Double-click **GRP_IT** → confirm **it.admin** is listed



Force GPO Update on All Windows VMs

Run this on DC01, then ADMIN01, then CL01 in PowerShell as Administrator:

```
gpupdate /force
```

```
C:\Users\Administrator>gpupdate /force
Updating policy...

Computer Policy update has completed successfully.
User Policy update has completed successfully.
```

VERIFY GPOs STILL APPLY AFTER GATEWAY CHANGE

Check GPO is Applying on CL01

Log in to CL01 as **CORP\hr.user**

Open PowerShell and run: gpresult /r

```
C:\Users\Administrator>gpresult /r

Microsoft (R) Windows (R) Operating System Group Policy Result tool v2.0
© Microsoft Corporation. All rights reserved.

Created on ⌈5/⌈2/⌈2026 at 10:58:57 AM


RSOP data for CORP\Administrator on ADMIN01 : Logging Mode
-------------------------------------------------------

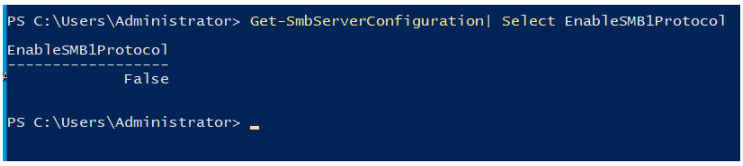
OS Configuration:            Member Workstation
OS Version:                  10.0.19045
Site Name:                   Default-First-Site-Name
Roaming Profile:             N/A
Local Profile:               C:\Users\Administrator
Connected over a slow link?: No
```

Look for **Applied Group Policy Objects** — you should see **user part of following security groups.**

```
The computer is a part of the following security groups
-------------------------------------------------------
    BUILTIN\Administrators
    Everyone
    BUILTIN\Users
    NT AUTHORITY\NETWORK
    NT AUTHORITY\Authenticated Users
    This Organization
    ADMIN01$
    Domain Computers
    Authentication authority asserted identity
    System Mandatory Level
```

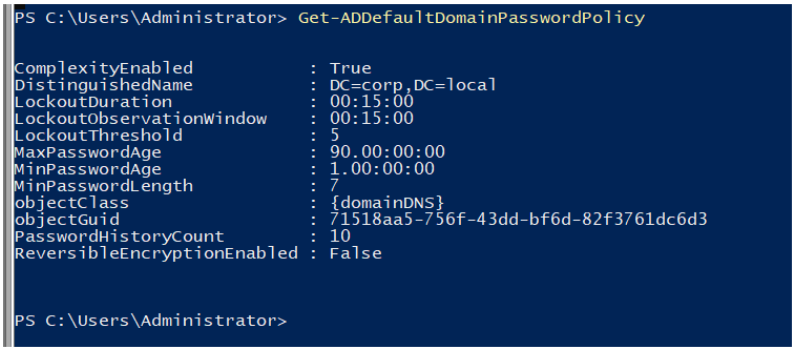
Verify SMBv1 Still Disabled (on DC01)

```
Get-SmbServerConfiguration | Select EnableSMB1Protocol
```



Verify Account Lockout Policy Still Active (on DC01)

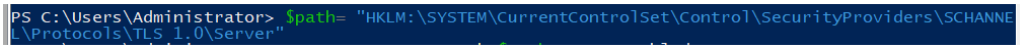
```
Get-ADDefaultDomainPasswordPolicy
```

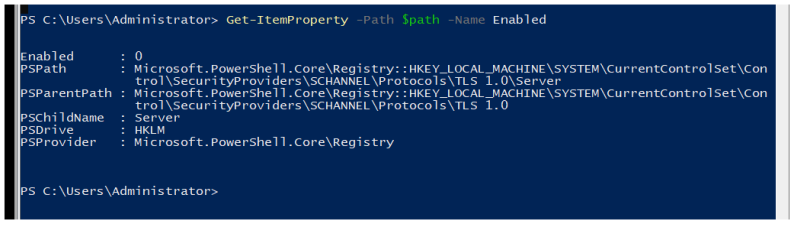


Verify TLS 1.0 is Still Disabled (on DC01)

```
$path =
"HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.0\Server"

Get-ItemProperty -Path $path -Name Enabled
```

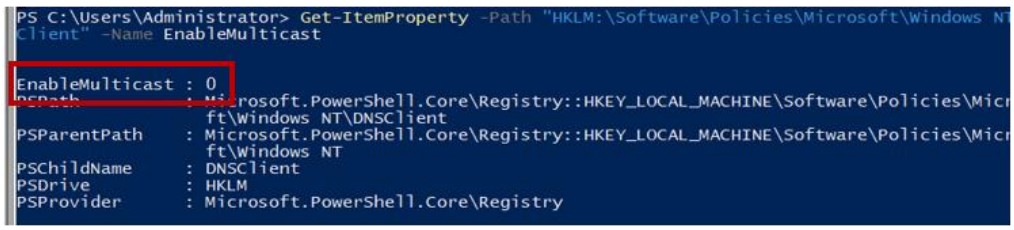




Expected: Enabled : 0

Verify LLMNR is Still Disabled (on DC01)

```
Get-ItemProperty -Path "HKLM:\SOFTWARE\Policies\Microsoft\Windows NT\DNSClient" -Name EnableMulticast
```



UPDATE SURICATA RULES ON IDS01

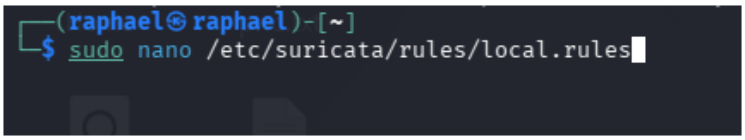
Open the Rules File

Log in to **IDS01** (Kali Linux)

Open a terminal

Run:

```
sudo nano /etc/suricata/rules/local.rules
```



Add SQL Injection Detection Rules

Paste these at the bottom:

```
alert http any any -> $HOME_NET any (msg:"SQL Injection - OR 1=1
Pattern"; content:"' OR"; nocase; http_uri; sid:9000010; rev:1;)

alert http any any -> $HOME_NET any (msg:"SQL Injection - UNION SELECT";
content:"UNION SELECT"; nocase; http_uri; sid:9000011; rev:1;)

alert http any any -> $HOME_NET any (msg:"SQL Injection - DROP TABLE";
content:"DROP TABLE"; nocase; http_uri; sid:9000012; rev:1;)

alert http any any -> $HOME_NET any (msg:"SQL Injection - Single Quote
Encoded"; content:"'%20OR%20'"; nocase; http_uri; sid:9000013; rev:1;)
```

Add XSS Detection Rules

```
alert http any any -> $HOME_NET any (msg:"XSS - Script Tag Detected";
content:"<script>"; nocase; http_uri; sid:9000020; rev:1;)

alert http any any -> $HOME_NET any (msg:"XSS - onerror Attribute";
content:"onerror="; nocase; http_uri; sid:9000021; rev:1;)

alert http any any -> $HOME_NET any (msg:"XSS - onload Attribute";
content:"onload="; nocase; http_uri; sid:9000022; rev:1;)

alert http any any -> $HOME_NET any (msg:"XSS - javascript Protocol";
content:"javascript:"; nocase; http_uri; sid:9000023; rev:1;)
```

Add Brute Force Detection Rules

```
alert tcp any any -> $HOME_NET 3389 (msg:"Brute Force - RDP Login Attempts"; threshold:type threshold, track by_src, count 10, seconds 60; sid:9000030; rev:1;)

alert tcp any any -> $HOME_NET 22 (msg:"Brute Force - SSH Login Attempts"; threshold:type threshold, track by_src, count 10, seconds 60; sid:9000031; rev:1;)

alert tcp any any -> $HOME_NET 445 (msg:"Brute Force - SMB Authentication"; threshold:type threshold, track by_src, count 5, seconds 30; sid:9000032; rev:1;)
```

Add LLMNR / NBT-NS Poisoning Detection Rules

```
alert udp any any -> 224.0.0.252 5355 (msg:"LLMNR Multicast Query - Possible Poisoning"; sid:9000040; rev:1;)

alert udp any any -> $HOME_NET 5355 (msg:"LLMNR Unicast Query Detected"; sid:9000041; rev:1;)

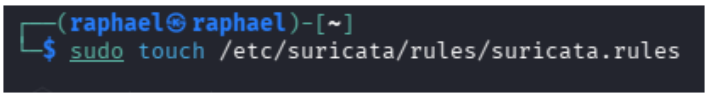
alert udp any any -> $HOME_NET 137 (msg:"NBT-NS Query Detected - Possible Poisoning"; sid:9000042; rev:1;)

alert udp any any -> $HOME_NET 138 (msg:"NetBIOS Datagram Service Traffic Detected"; sid:9000043; rev:1;)
```



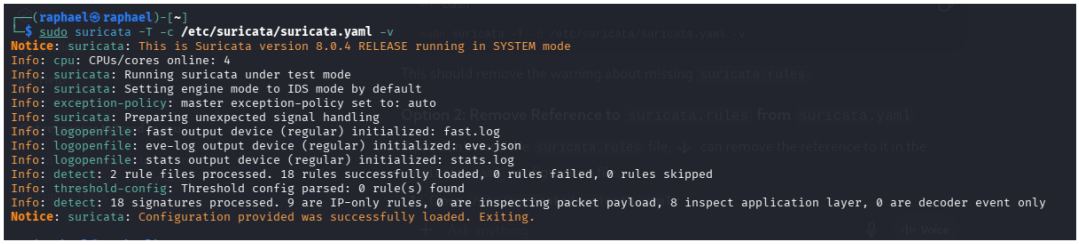
Save, Test, and Restart Suricata

Press **Ctrl+S** to save, then **Ctrl+X** to exit nano.



Test for syntax errors:

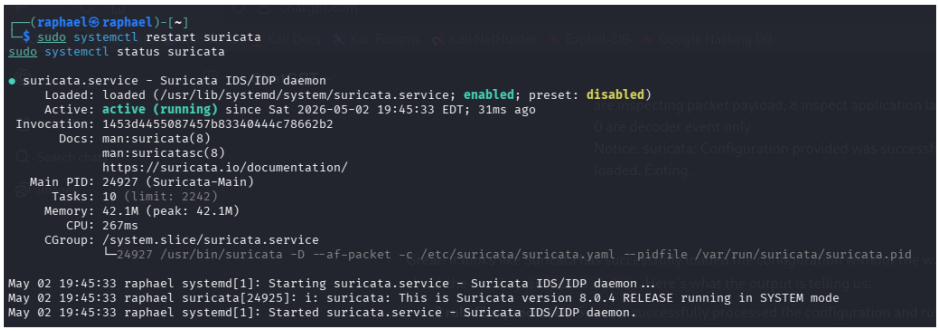
```
sudo suricata -T -c /etc/suricata/suricata.yaml -v
```



Restart Suricata:

```
sudo systemctl restart suricata

sudo systemctl status suricata
```



Open the live alert monitor (keep this terminal visible during attacks):

```
sudo tail -f /var/log/suricata/fast.log
```



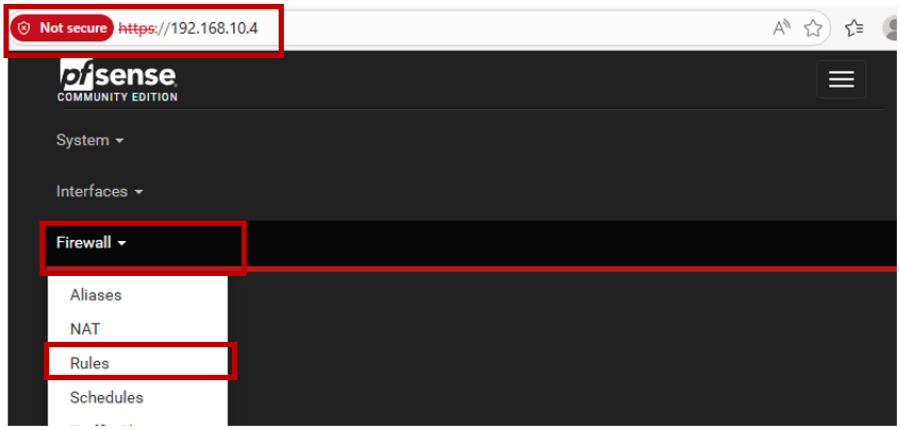
VERIFY VPN01 STILL WORKS WITH pfSense GATEWAY

Add pfSense Pass Rule for VPN Client Traffic

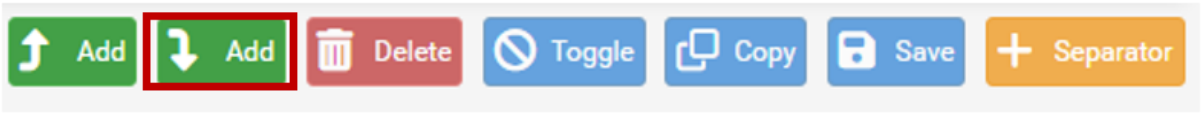
SoftEther assigns VPN clients IPs in the 192.168.30.x range. pfSense needs a rule to allow this traffic to reach the internal lab.

In pfSense web UI (https://192.168.10.4) from ADMIN01):

Go to Firewall → Rules → LAN

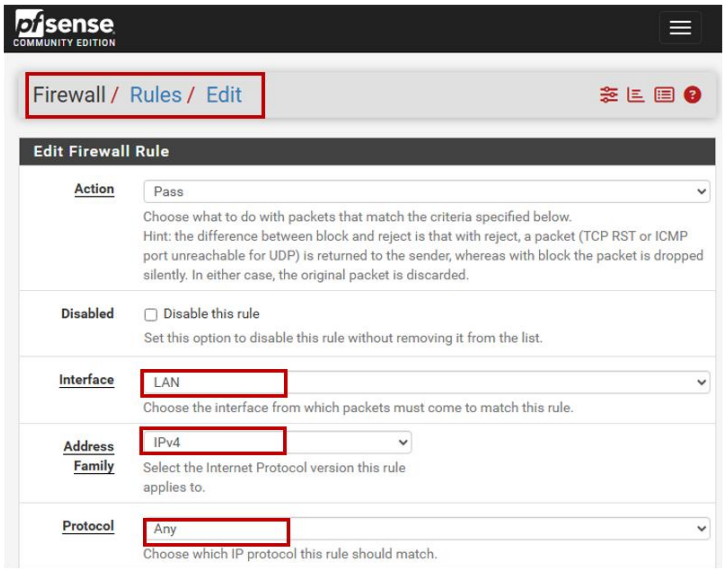


Click Add (down-arrow — add to bottom)



Action: Pass

Protocol: any

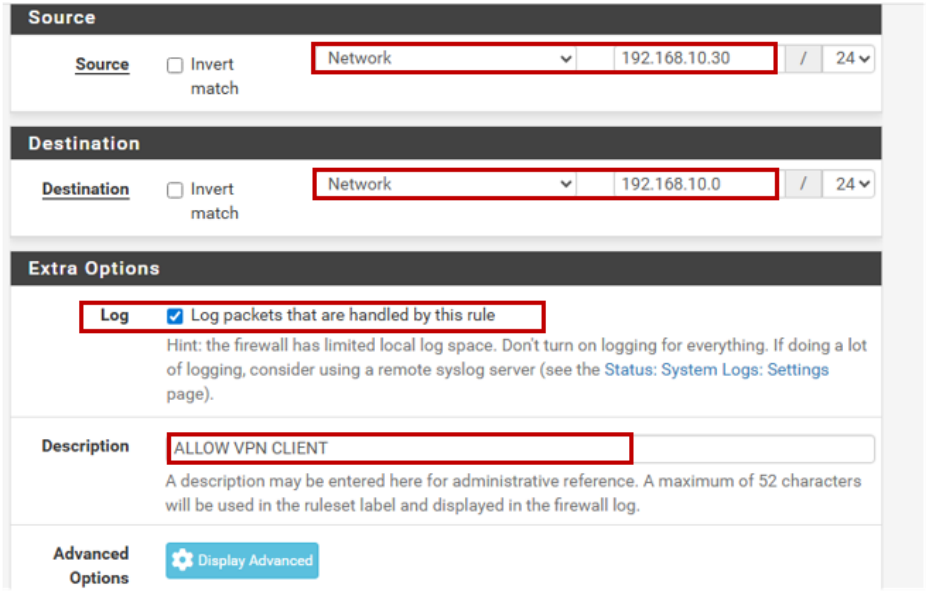


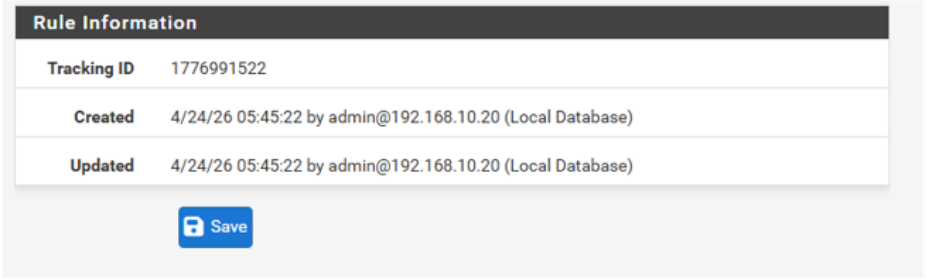
Source: Network → 192.168.30.0 / 24

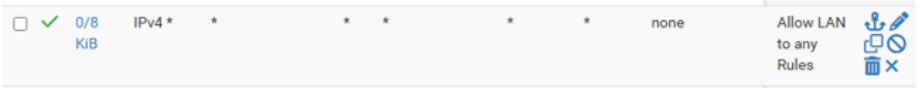
Destination: Network → 192.168.10.0 / 24

Description: Allow-VPN-Clients-to-LAN

Click Save → Apply Changes





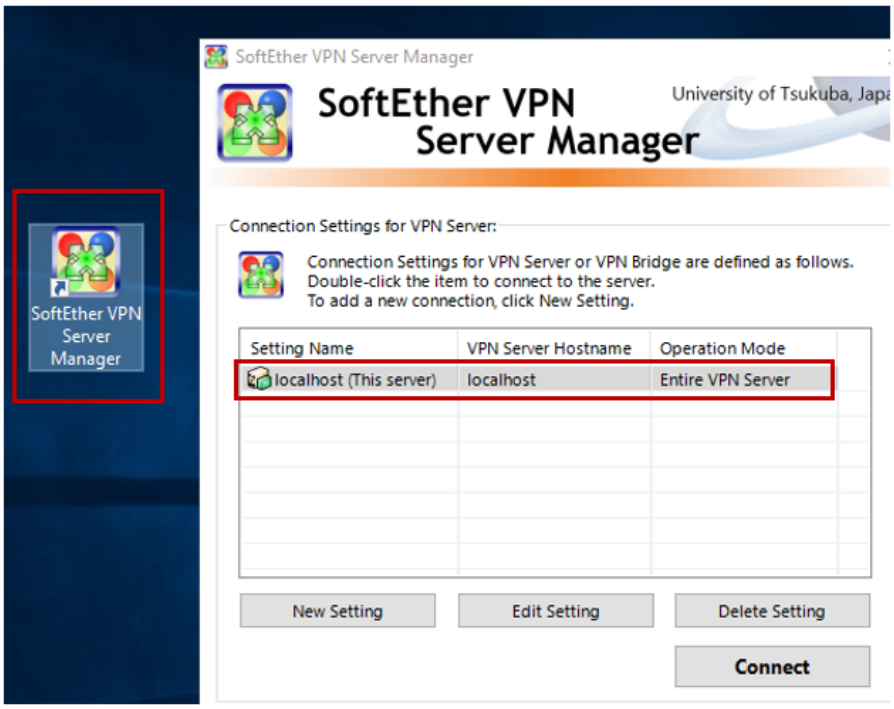


Confirm SoftEther VPN is Still Running on VPN01

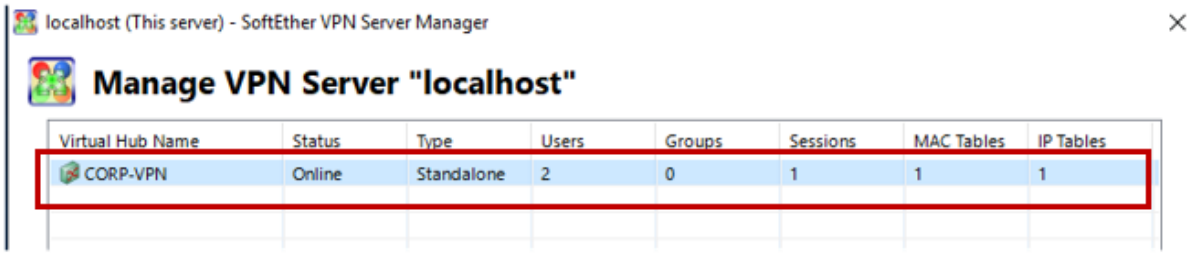
Log in to VPN01 as CORP\Administrator

Open SoftEther VPN Server Manager from the desktop or Start Menu

Double-click localhost → enter password Admin123 → click Connect

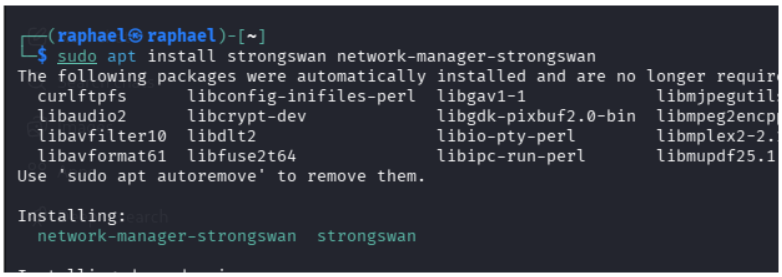


You should see CORP-VPN hub with status: Online



Test VPN Connection from ATTACK01

On ATTACK01 open a terminal:





Select: Layer 2 Tunneling Protocol (L2TP) → Create



Name: CORP-VPN-Test

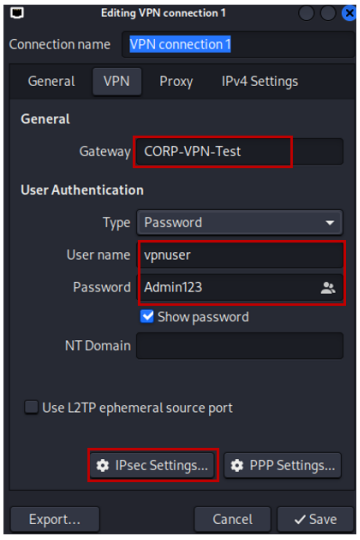
Gateway: 192.168.10.50

Username: vpnuser

Password: Admin123

NT Domain: leave blank

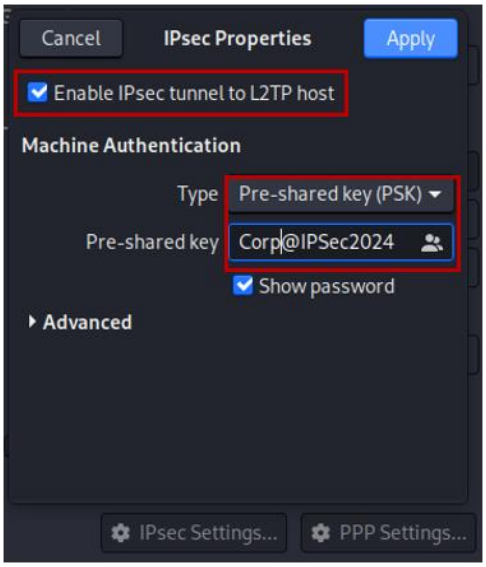
Click IPsec Settings:



Check: Enable IPsec tunnel to L2TP host

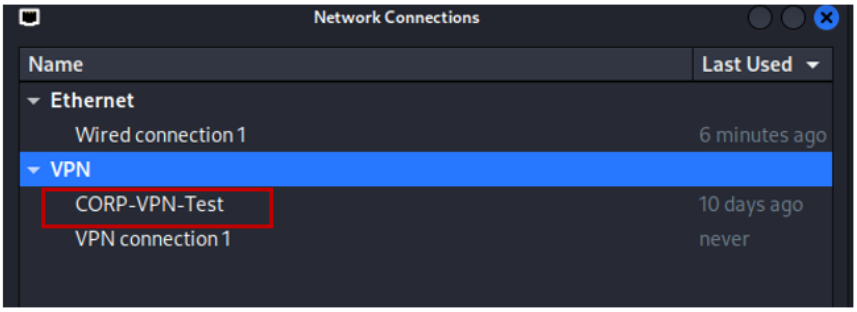
Pre-shared key: Corp@IPSec2024

Click OK



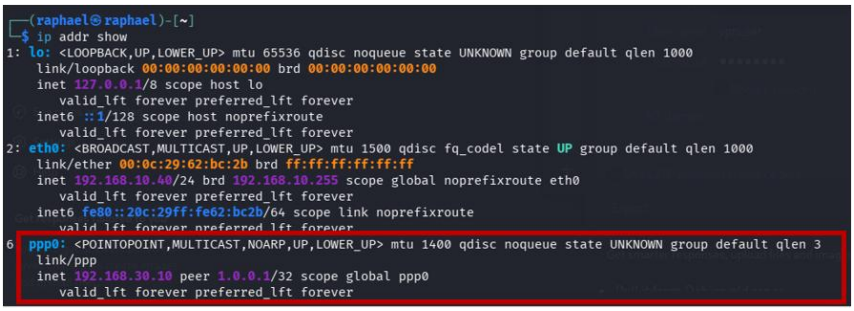
Click Save

Toggle the VPN connection ON



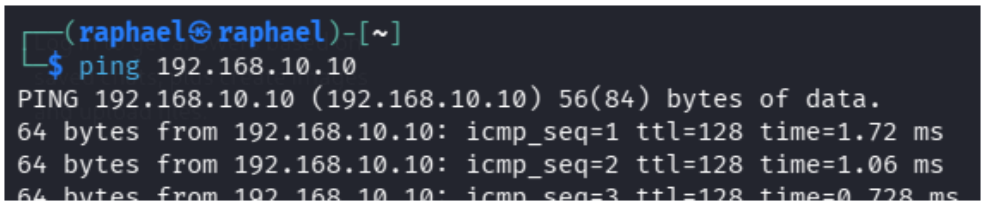
Verify:

ip addr show

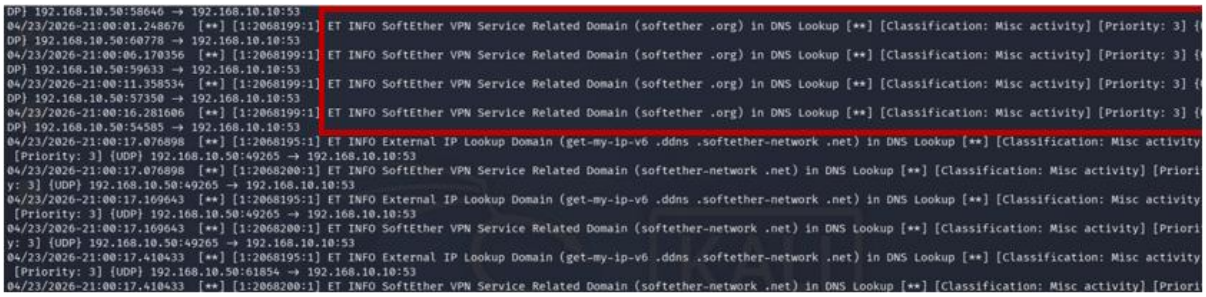


```
ping 192.168.10.10
```

DC01 will reply through the VPN tunnel



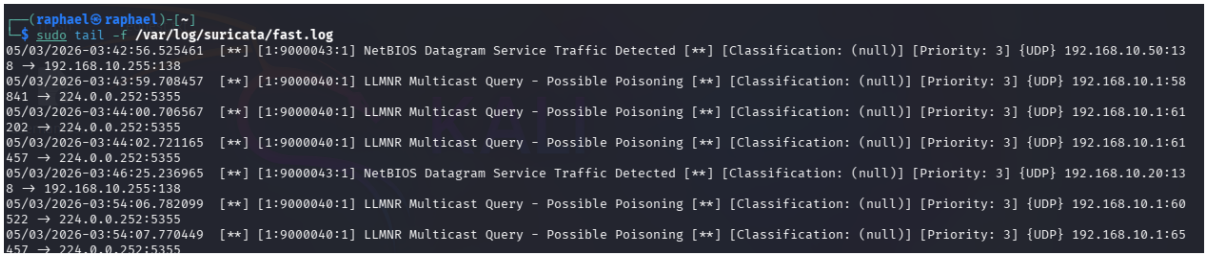
Suricata detecting soft Ether VPN Connection



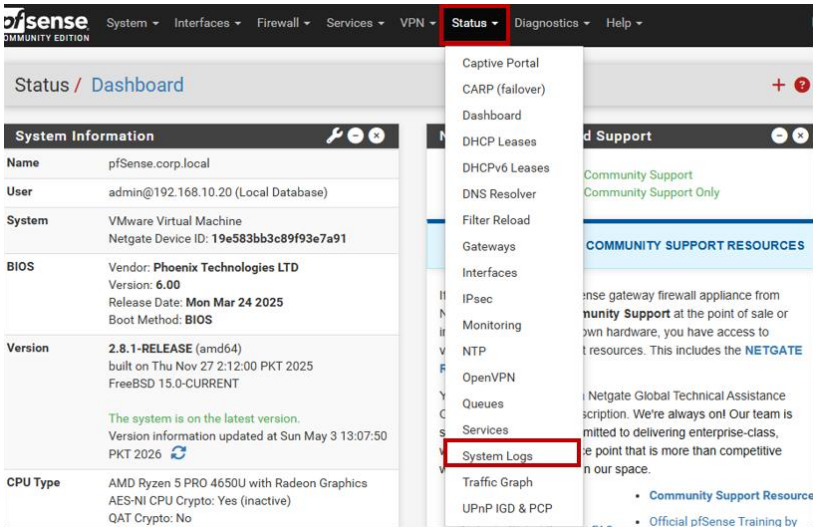
ATTACK SIMULATION (All from ATTACK01)

Before starting any attack: on IDS01 run and keep that terminal visible, Turn of the VPN as well.

```
sudo tail -f /var/log/suricata/fast.log
```



Also keep the pfSense web UI open on ADMIN01 at **Status → System Logs → Firewall** so you can watch both simultaneously.



Attack 1 — Network Reconnaissance

Goal: Discover all live hosts and open ports.

Aggressive Scan

```
nmap -A -T5 192.168.10.10
```

```
┌──(raphael㉿raphael)-[~]
└─$ nmap -A -T5 192.168.10.10
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-03 04:08 -0400
Nmap scan report for 192.168.10.10
Host is up (0.0010s latency).
Not shown: 987 filtered tcp ports (no-response)
PORT     STATE SERVICE       VERSION
22/tcp   open  ssh           OpenSSH for_Windows_7.7 (protocol 2.0)
| ssh-hostkey:
```

Port scan DC01

```
nmap -sS -p 1-1024 192.168.10.10
```

```
┌──(raphael㉿raphael)-[~]
└─$ nmap -sS -p 1-1024 192.168.10.10
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-03 04:10 -0400
Nmap scan report for 192.168.10.10
Host is up (0.00091s latency).
Not shown: 1014 filtered tcp ports (no-response)
PORT    STATE SERVICE
22/tcp  open  ssh
53/tcp  open  domain
80/tcp  open  http
88/tcp  open  kerberos-sec
135/tcp open  msrpc
389/tcp open  ldap
445/tcp open  microsoft-ds
464/tcp open  kpasswd5
593/tcp open  http-rpc-epmap
636/tcp open  ldapssl
MAC Address: 00:0C:29:DB:5E:B9 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 5.64 seconds
```

Full aggressive scan with OS and version detection

```
nmap -A -T4 192.168.10.10
```

```
┌──(raphael㉿raphael)-[~]
└─$ nmap -A -T4 192.168.10.10
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-03 04:11 -0400
Nmap scan report for 192.168.10.10
Host is up (0.0012s latency).
Not shown: 987 filtered tcp ports (no-response)
PORT     STATE SERVICE       VERSION
```

Scan VPN server UDP ports

```
nmap -sU -p 500,1701,4500 192.168.10.50
```

```
┌──(raphael㉿raphael)-[~]
└─$ nmap -sU -p 500,1701,4500 192.168.10.50
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-03 04:13 -0400
Nmap scan report for 192.168.10.50
Host is up (0.0012s latency).

PORT     STATE         SERVICE
500/udp  open          isakmp
1701/udp closed        L2TP
4500/udp open|filtered nat-t-ike
MAC Address: 00:0C:29:BC:41:FD (VMware)

Nmap done: 1 IP address (1 host up) scanned in 2.08 seconds
```

Attack 2 — SMBv1 / EternalBlue Check (Verification)

Goal: Confirm SMBv1 is properly disabled — this attack should FAIL, proving your Module 3 hardening worked.

Check what SMB versions DC01 supports

```
nmap --script smb-protocols 192.168.10.10
```

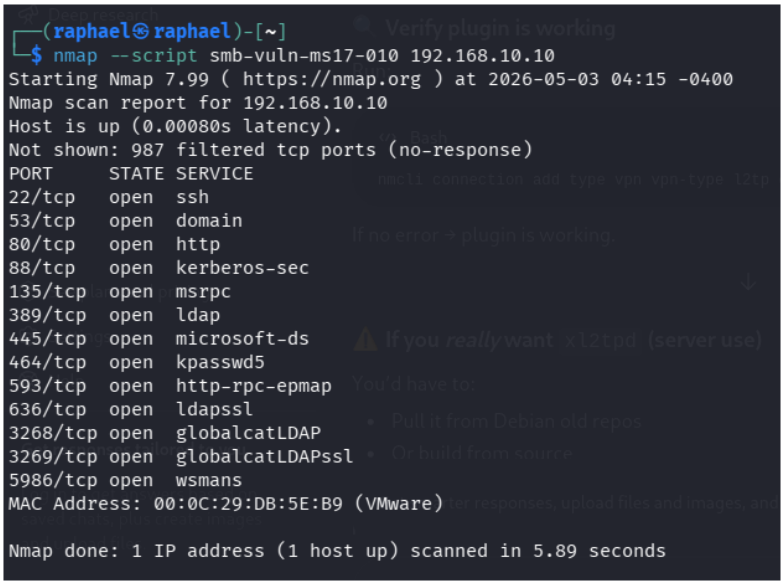
```
┌──(raphael㉿raphael)-[~]
└─$ nmap --script smb-protocols 192.168.10.10
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-03 04:14 -0400
Nmap scan report for 192.168.10.10
Host is up (0.00084s latency).
Not shown: 987 filtered tcp ports (no-response)
PORT     STATE SERVICE
22/tcp   open  ssh
53/tcp   open  domain
80/tcp   open  http
88/tcp   open  kerberos-sec
135/tcp  open  msrpc
389/tcp  open  ldap
445/tcp  open  microsoft-ds
464/tcp  open  kpasswd5
593/tcp  open  http-rpc-epmap
636/tcp  open  ldapssl
3268/tcp open  globalcatLDAP
3269/tcp open  globalcatLDAPssl
5986/tcp open  wsmans
MAC Address: 00:0C:29:DB:5E:B9 (VMware)

Host script results:
| smb-protocols:
|   dialects:
|     2.0.2
|     2.1
|     3.0
|     3.0.2
|_    3.1.1

Nmap done: 1 IP address (1 host up) scanned in 11.22 seconds
```

```
# Test for EternalBlue vulnerability

nmap --script smb-vuln-ms17-010 192.168.10.10
```



Expected: SMBv1 does NOT appear in the output. The vuln script shows no VULNERABLE section.

Attack 3 — Brute Force Attack

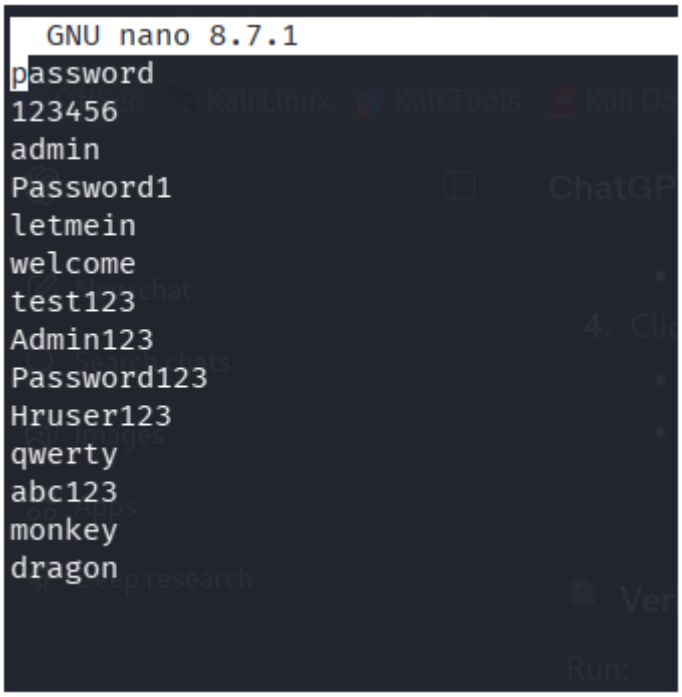
Goal: Trigger account lockout and IDS brute force alert.

First, create a password wordlist on ATTACK01:

```
nano mywordlist.txt
```



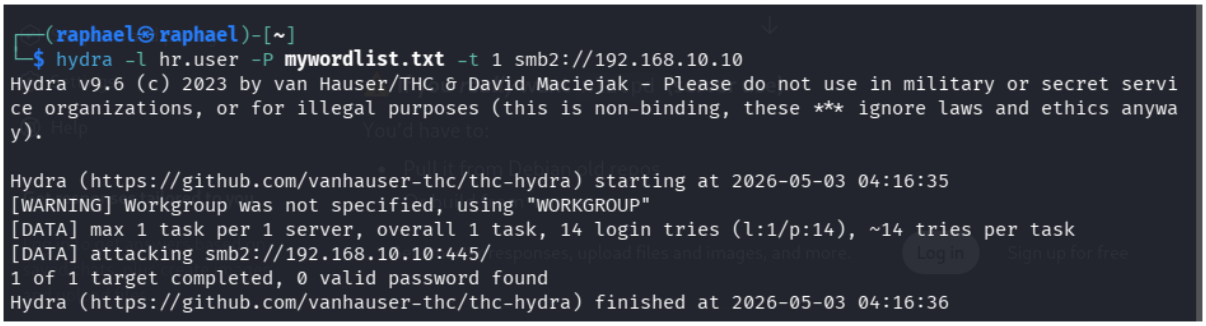
Type these passwords, one per line:



Press **Ctrl+S** then **Ctrl+X** to save.

Run Hydra:

```
hydra -l hr.user -P mywordlist.txt -t 1 smb2://192.168.10.10
```



After 5 failed attempts the account locks. Hydra cannot find valid credentials.

Attack 4 — LLMNR Poisoning Test

Goal: Confirm LLMNR is disabled — if it is properly off, Responder captures nothing.

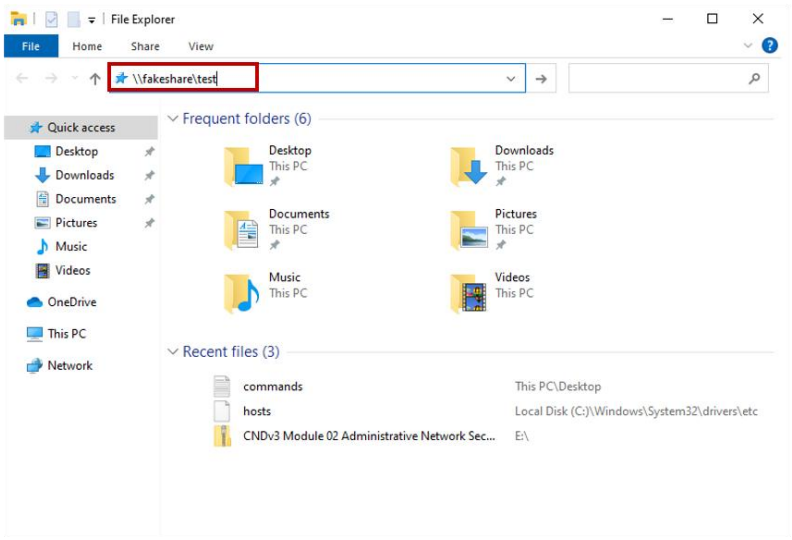
On ATTACK01, start Responder:

```
sudo responder -I eth0 -wv
```

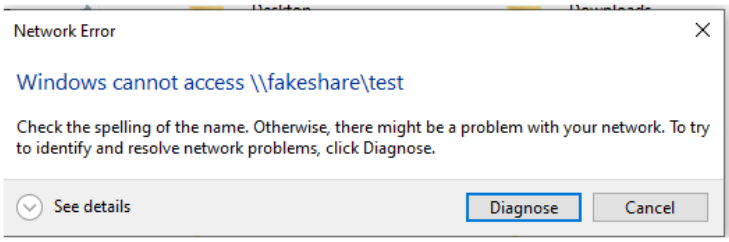


Leave it running and switch to CL01:

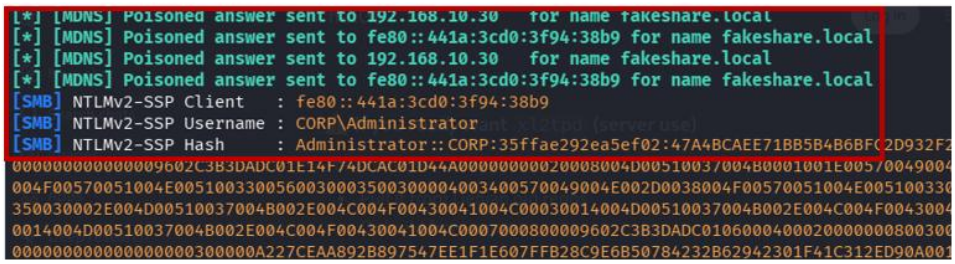
On CL01, open File Explorer. In the address bar at the top type: \\fakeshare\test → press Enter



CL01 tries to find a server called "fakeshare". If LLMNR is properly disabled, it will not broadcast an LLMNR query and Responder on ATTACK01 captures no hashes.



Responder Results checking



Attack 5 — SQL Injection Test

Run these commands for SQL Injection on ATTACK01

```
curl "http://192.168.10.10/Login.aspx" --data "username=' OR '1'='1&password=test"
```

```
┌──(raphael㉿raphael)-[~]
└─$ curl "http://192.168.10.10/Login.aspx" --data "username=' OR '1'='1&password=test"

<html>
<head><title>Company Login</title></head>
<body>
    <h2>Login</h2>
    <form method="post">
        Username: <input type="text" name="username" /><br />
        Password: <input type="password" name="password" /><br />
        <input type="submit" value="Login" />
    </form>
<h3>Invalid password</h3>

</body>
</html>
```

```
curl "http://192.168.10.10/Login.aspx" --data "username=' UNION SELECT 1,2--&password=test"
```

```
┌──(raphael㉿raphael)-[~]
└─$ curl "http://192.168.10.10/Login.aspx" --data "username=' UNION SELECT 1,2 --&password=test"
<!DOCTYPE html>
<html>
    <head>
        <title>All queries combined using a UNION, INTERSECT or EXCEPT operator must have an equal num
ber of expressions in their target lists.</title>
        <meta name="viewport" content="width=device-width" />
        <style>
         body {font-family:"Verdana";font-weight:normal;font-size: .7em;color:black;}
         p {font-family:"Verdana";font-weight:normal;color:black;margin-top: -5px}
         b {font-family:"Verdana";font-weight:bold;color:black;margin-top: -5px}
         H1 { font-family:"Verdana";font-weight:normal;font-size:18pt;color:red }
         H2 { font-family:"Verdana";font-weight:normal;font-size:14pt;color:maroon }
         pre {font-family:"Consolas","Lucida Console",Monospace;font-size:11pt;margin:0;padding:0.5em;
line-height:14pt}
         .marker {font-weight: bold; color: black;text-decoration: none;}
         .version {color: gray;}
         .error {margin-bottom: 10px;}
         .expandable { text-decoration:underline; font-weight:bold; color:navy; cursor:pointer; }
         @media screen and (max-width: 639px) {
          pre { width: 440px; overflow: auto; white-space: pre-wrap; word-wrap: break-word; }
         }
         @media screen and (max-width: 479px) {
          pre { width: 280px; }
         }
        </style>
    </head>

    <body bgcolor="white">

            <span><H1>Server Error in '/' Application.<hr width=100% size=1 color=silver></H1>
```

Attack 6 — XSS Test

```
curl "http://192.168.10.10/Comments.aspx" --data
"comment=<script>alert(1)</script>"
```

```
┌──(raphael㉿raphael)-[~]
└─$ curl "http://192.168.10.10/Comments.aspx" --data "comment=<script>alert(1)</script>"

<!DOCTYPE html>
<html>
<head>
    <title>Comments Page</title>
</head>
<body>

<h2>Leave a Comment</h2>

<form method="post">
    Username:<br />
    <input type="text" name="username" /><br /><br />

    Comment:<br />
    <textarea name="comment" rows="4" cols="50"></textarea><br /><br />

    <input type="submit" value="Submit Comment" />
</form>

<hr />
<h3>All Comments:</h3>

<b>attacker</b>: <script>alert(1)</script><br /><br /><b>attacker</b>: <script>alert(1)</script><br />
<br /><b>attacker</b>: <script>alert('XSS')</script><br /><br /><b>rafay</b>: <script>alert('Hacked')<
/script><br /><br /><b>attacker</b>: <script>alert('Network Security Module')</script><br /><br /><b>a
dmin</b>: <script>alert('Testing Xss')</script><br /><br /><b></b>: <script>alert(1)</script><br /><br
 /><b></b>: <img src=x onerror=alert(1)><br /><br /><b></b>: <script>alert(1)</script><br /><br />

</body>
</html>
```

```
curl "http://192.168.10.10/Comments.aspx" --data "comment=<img src=x
onerror=alert(1)>"
```

```
┌──(raphael㉿raphael)-[~]
└─$ curl "http://192.168.10.10/Comments.aspx" --data "comment=<img src = x omerror=alert(1)>"


<!DOCTYPE html>
<html>
<head>
    <title>Comments Page</title>
</head>
<body>

<h2>Leave a Comment</h2>

<form method="post">
    Username:<br />
    <input type="text" name="username" /><br /><br />

    Comment:<br />
    <textarea name="comment" rows="4" cols="50"></textarea><br /><br />

    <input type="submit" value="Submit Comment" />
</form>

<hr />
<h3>All Comments:</h3>

<b>attacker</b>: <script>alert(1)</script><br /><br /><b>attacker</b>: <script>alert(1)</script><br />
<br /><b>attacker</b>: <script>alert('XSS')</script><br /><br /><b>rafay</b>: <script>alert('Hacked')<
/script><br /><br /><b>attacker</b>: <script>alert('Network Security Module')</script><br /><br /><b>a
dmin</b>: <script>alert('Testing Xss')</script><br /><br /><b></b>: <script>alert(1)</script><br /><br
 /><b></b>: <img src=x onerror=alert(1)><br /><br /><b></b>: <script>alert(1)</script><br /><br /><b><
/b>: <img src = x omerror=alert(1)><br /><br />

</body>
</html>
```

Attack 7 — VPN Access Validation

Confirm VPN ports are open

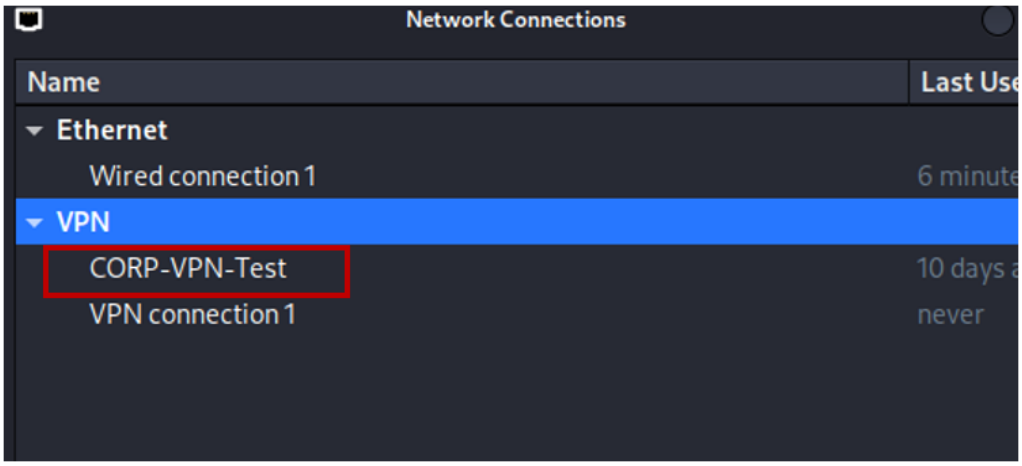
```
nmap -sU -p 500,1701,4500 192.168.10.50
```

```
┌──(raphael㉿raphael)-[~]
└─$ nmap -sU -p 500,1701,4500 192.168.10.50
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-03 04:26 -0400
Nmap scan report for 192.168.10.50
Host is up (0.00088s latency).

PORT     STATE         SERVICE
500/udp  open          isakmp
1701/udp closed        L2TP
4500/udp open|filtered nat-t-ike
MAC Address: 00:0C:29:BC:41:FD (VMware)

Nmap done: 1 IP address (1 host up) scanned in 1.97 seconds
```

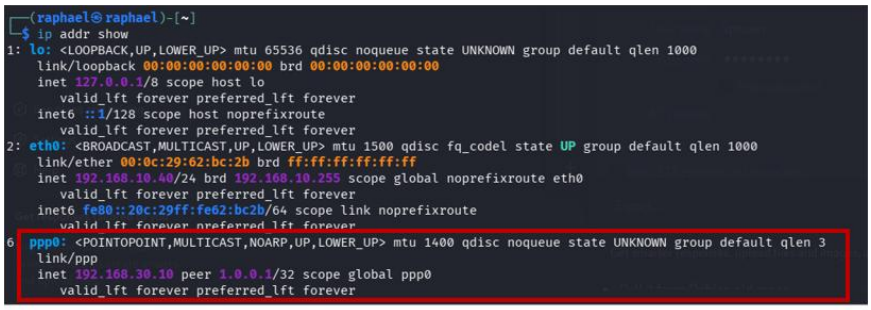
Connect to VPN with valid credentials (toggle the CORP-VPN-Test connection)



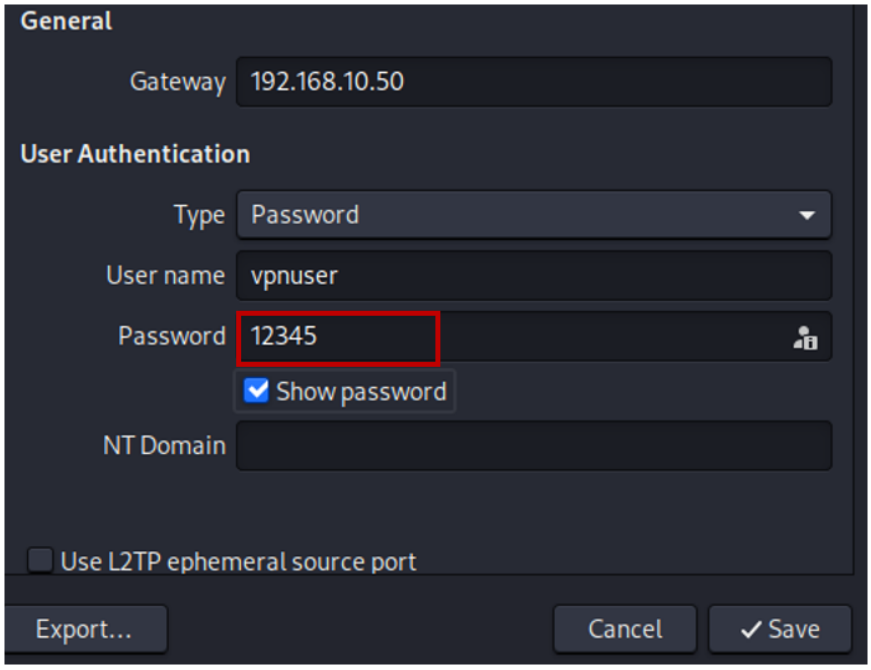
Then run this command

ip addr show

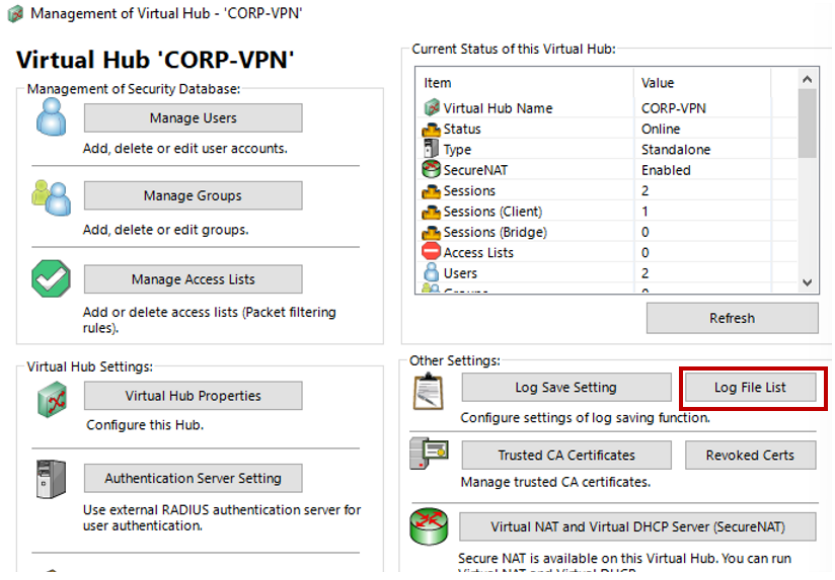
Look for ppp0 with 192.168.30.x IP

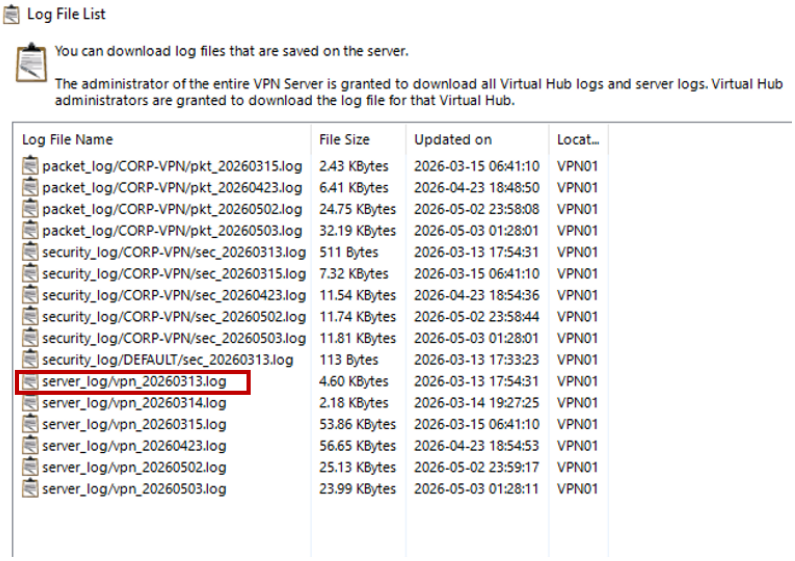


Then test with wrong credentials: edit the VPN connection, change password to wrong password, try to connect.

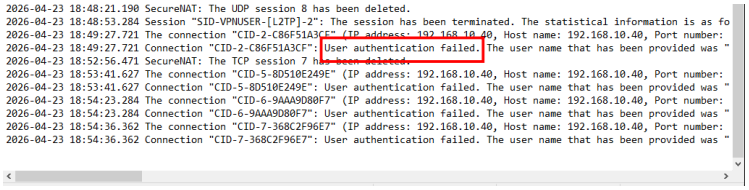


Connection should fail. Check SoftEther VPN Server Manager on VPN01





You will see the failed auth attempt in the server log.



Attack 8 — TLS Version Verification

Goal: Confirm TLS 1.0 and 1.1 are rejected, only TLS 1.2 is accepted.

Scan TLS on LDAPS port

nmap --script ssl-enum-ciphers -p 636 192.168.10.10

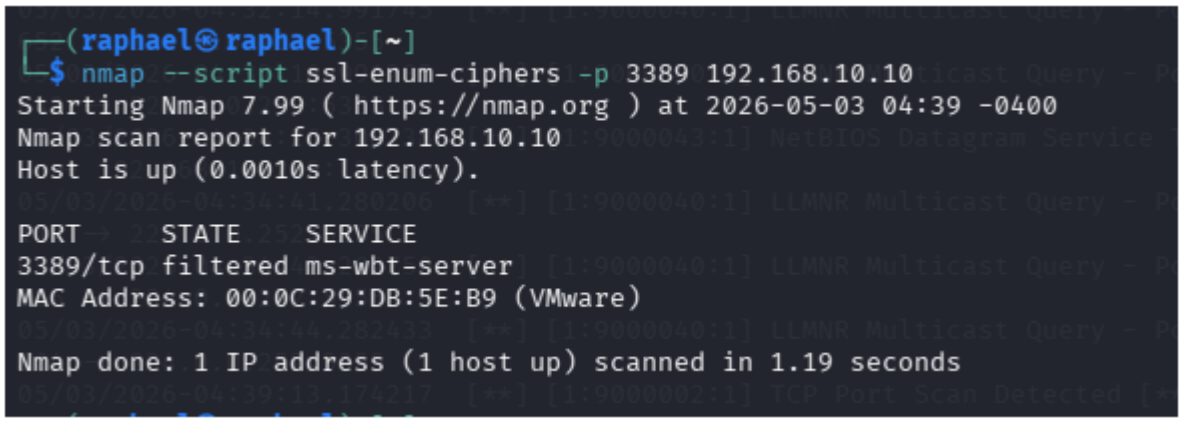
```
┌──(raphael㉿raphael)-[~]
└─$ nmap --script ssl-enum-ciphers -p 636 192.168.10.10
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-03 04:39 -0400
Nmap scan report for 192.168.10.10
Host is up (0.0015s latency).

PORT    STATE SERVICE
636/tcp open  ldapssl
| ssl-enum-ciphers:
|   TLSv1.2:
|     ciphers:
|       TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 (secp384r1) - A
|       TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 (ecdh_x25519) - A
|       TLS_DHE_RSA_WITH_AES_256_GCM_SHA384 (dh 2048) - A
|       TLS_DHE_RSA_WITH_AES_128_GCM_SHA256 (dh 2048) - A
|       TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384 (secp384r1) - A
|       TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA256 (ecdh_x25519) - A
|       TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (secp384r1) - A
|       TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA (ecdh_x25519) - A
|       TLS_RSA_WITH_AES_256_GCM_SHA384 (rsa 2048) - A
|       TLS_RSA_WITH_AES_128_GCM_SHA256 (rsa 2048) - A
|       TLS_RSA_WITH_AES_256_CBC_SHA256 (rsa 2048) - A
|       TLS_RSA_WITH_AES_128_CBC_SHA256 (rsa 2048) - A
|       TLS_RSA_WITH_AES_256_CBC_SHA (rsa 2048) - A
|       TLS_RSA_WITH_AES_128_CBC_SHA (rsa 2048) - A
|       TLS_RSA_WITH_3DES_EDE_CBC_SHA (rsa 2048) - C
|     compressors:
|       NULL
|     cipher preference: server
|     warnings:
|       64-bit block cipher 3DES vulnerable to SWEET32 attack
|_  least strength: C
MAC Address: 00:0C:29:DB:5E:B9 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 1.82 seconds
```

Scan TLS on RDP port

```
nmap --script ssl-enum-ciphers -p 3389 192.168.10.10
```



Only **TLSv1.2** appears. TLSv1.0 and TLSv1.1 should NOT be listed at all.

MONITORING AND LOGGING-VERIFICATION

Verify Sysmon is Running

On DC01 PowerShell:

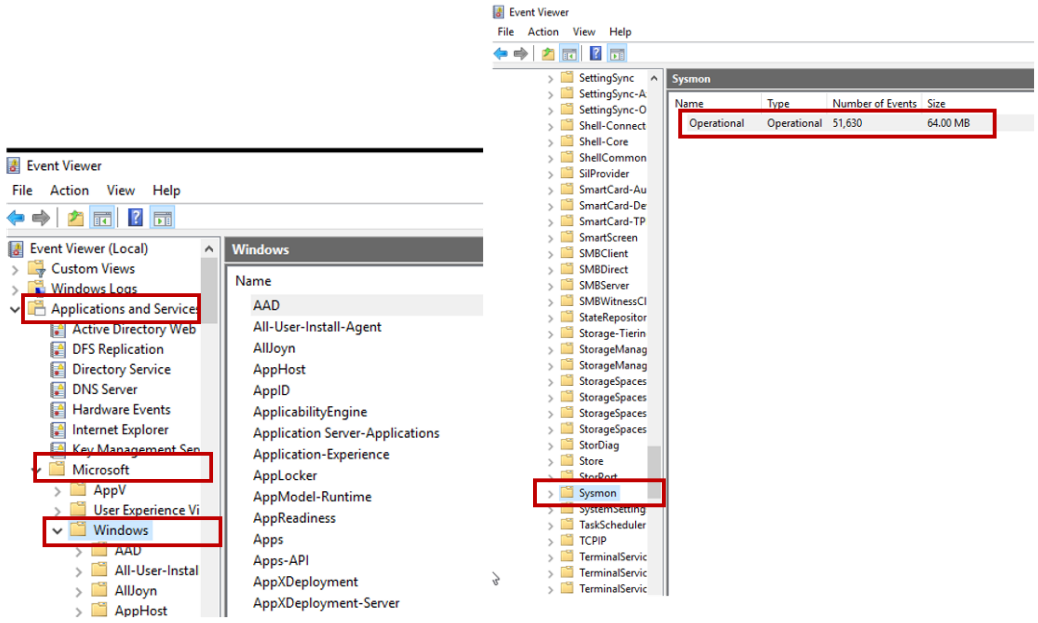
```
Get-Service sysmon64

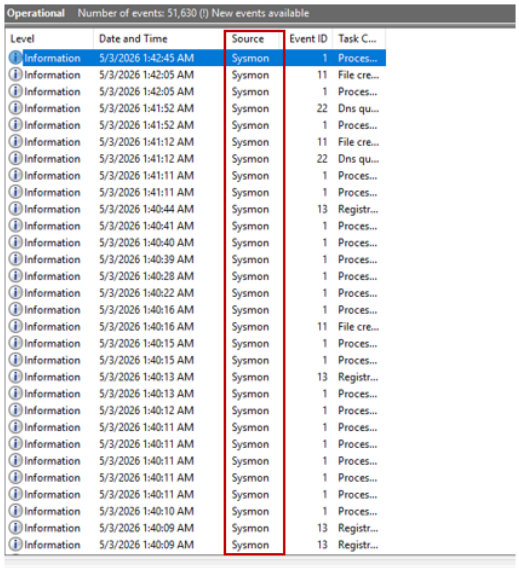
# Should show: Status = Running
```

```
PS C:\Users\Administrator> Get-Service sysmon64

Status   Name               DisplayName
------   ----               -----------
Running  Sysmon64           sysmon64
```

Go to Event Viewer and check for Sysmon Logs

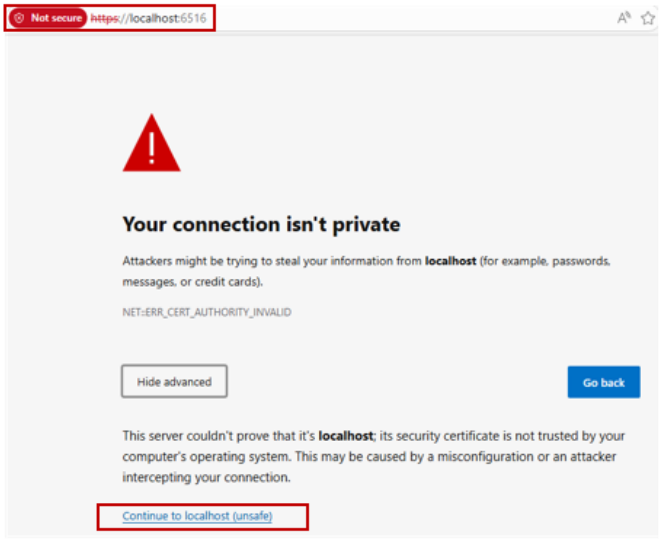


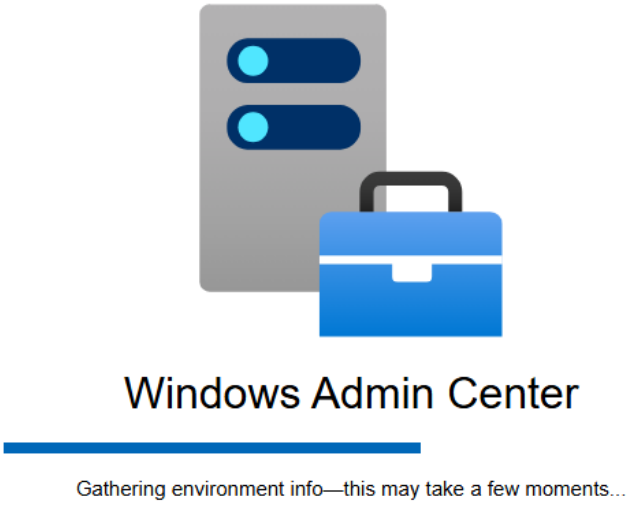


Check Windows Admin Center

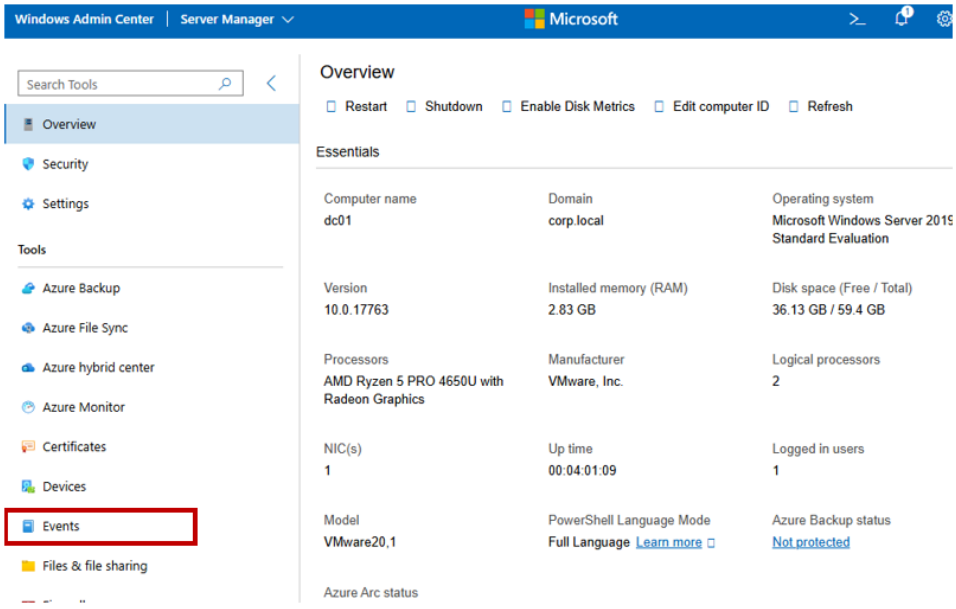
On ADMIN01 browser: https://localhost:6516

Click **DC01** in the server list → confirm Overview shows CPU and RAM

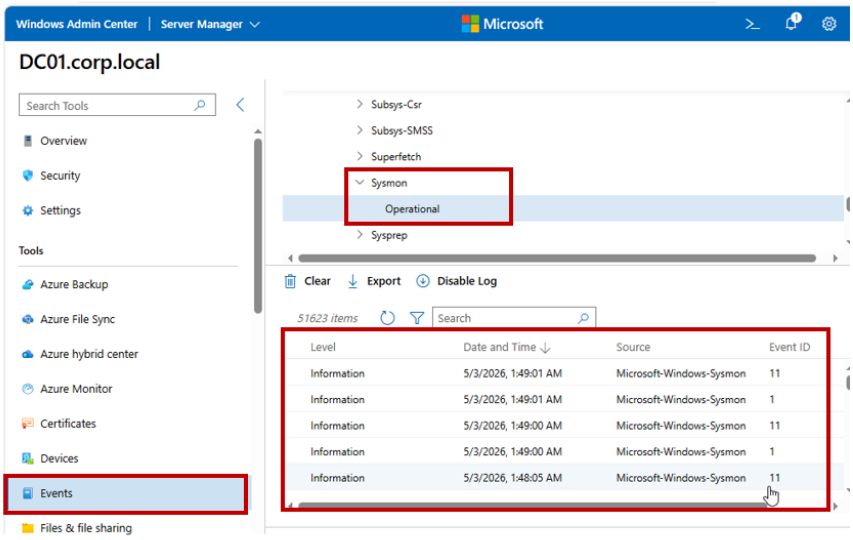




Click **Events** → confirm Security logs are loading



Application & services logs/Microsoft/Windows/Sysmon/OPeration

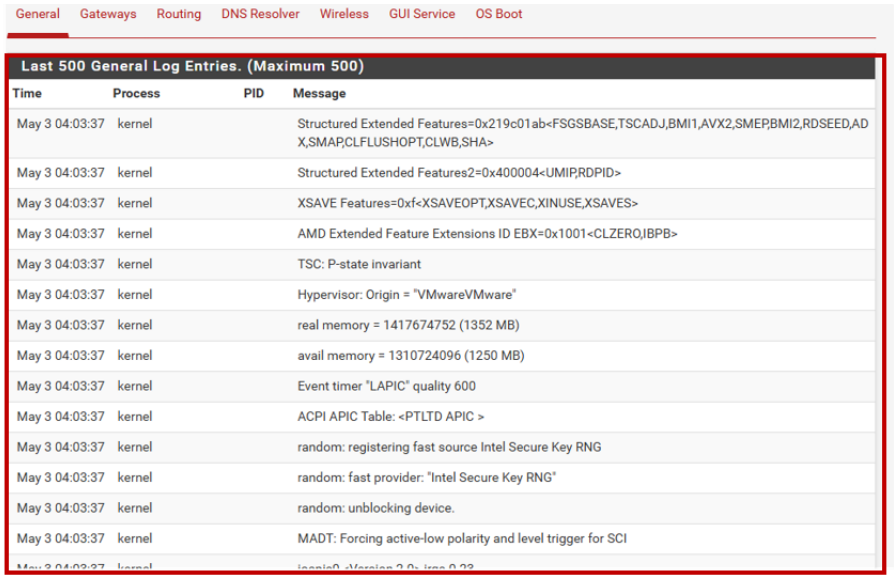


Click **PowerShell** → run hostname → should return DC01

```
PS C:\Users\Administrator> hostname
DC01
```

View pfSense Logs During Attacks

Checked Firewall wall logs

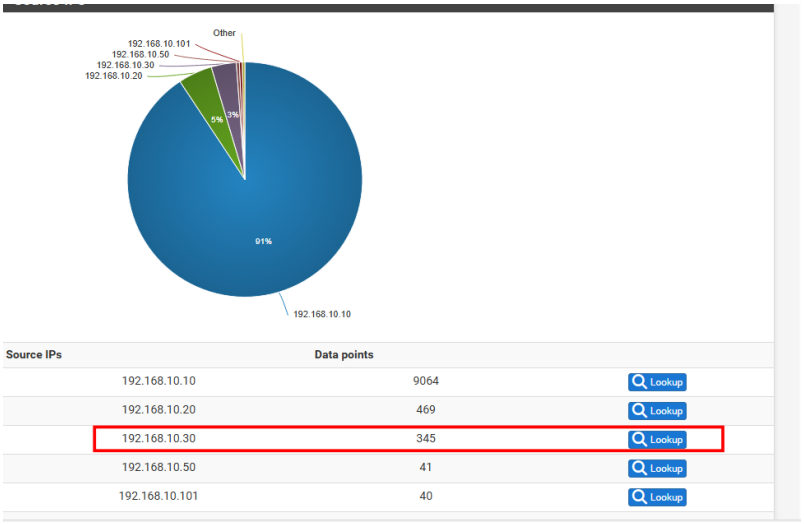


General | Gateways | Routing | DNS Resolver | Wireless | GUI Service | OS Boot

Last 500 General Log Entries. (Maximum 500)

Time	Process	PID	Message
May 3 04:03:37	kernel		Structured Extended Features=0x219c01ab<FSGSBASE,TSCADJ,BMI1,AVX2,SMEP,BMI2,RDSEED,ADX,SMAP,CLFLUSHOPT,CLWB,SHA>
May 3 04:03:37	kernel		Structured Extended Features2=0x400004<UMIP,RDPID>
May 3 04:03:37	kernel		XSAVE Features=0xf<XSAVEOPT,XSAVEC,XINUSE,XSAVES>
May 3 04:03:37	kernel		AMD Extended Feature Extensions ID EBX=0x1001<CLZERO,IBPB>
May 3 04:03:37	kernel		TSC: P-state invariant
May 3 04:03:37	kernel		Hypervisor: Origin = "VMwareVMware"
May 3 04:03:37	kernel		real memory = 1417674752 (1352 MB)
May 3 04:03:37	kernel		avail memory = 1310724096 (1250 MB)
May 3 04:03:37	kernel		Event timer "LAPIC" quality 600
May 3 04:03:37	kernel		ACPI APIC Table: <PTLTD APIC >
May 3 04:03:37	kernel		random: registering fast source Intel Secure Key RNG
May 3 04:03:37	kernel		random: fast provider: "Intel Secure Key RNG"
May 3 04:03:37	kernel		random: unblocking device.
May 3 04:03:37	kernel		MADT: Forcing active-low polarity and level trigger for SCI

Used dynamic view because the logs file exceeded the limit.



Source IPs	Data points	
192.168.10.10	9064	Lookup
192.168.10.20	469	Lookup
192.168.10.30	345	Lookup
192.168.10.50	41	Lookup
192.168.10.101	40	Lookup

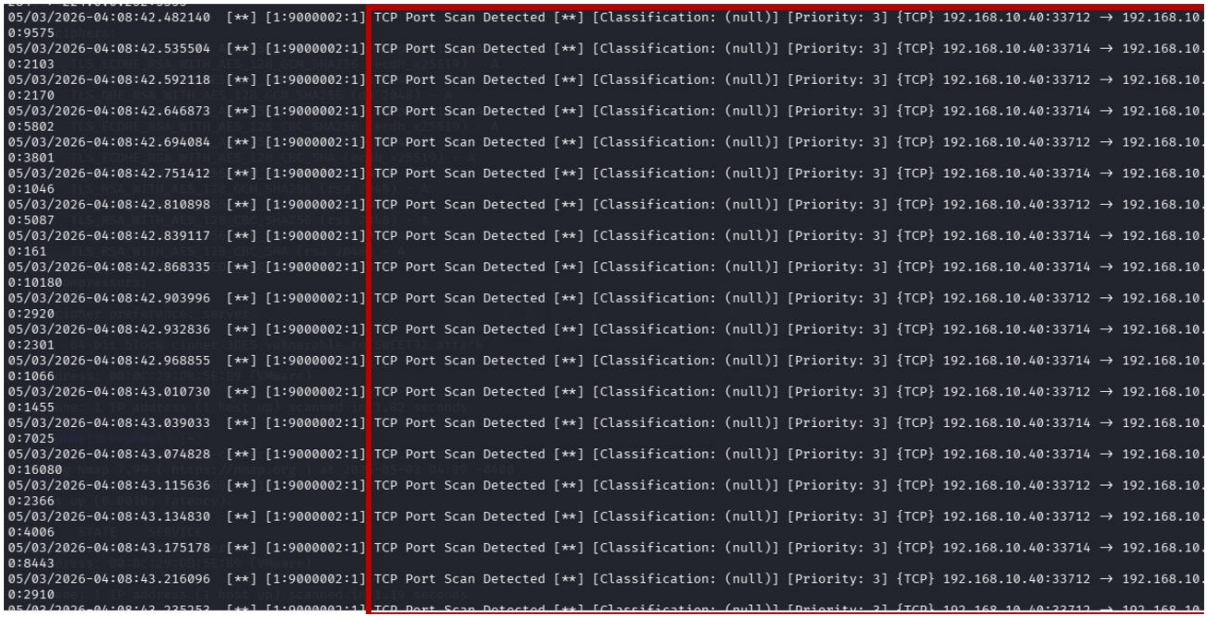
View IDS Logs

Brute Force

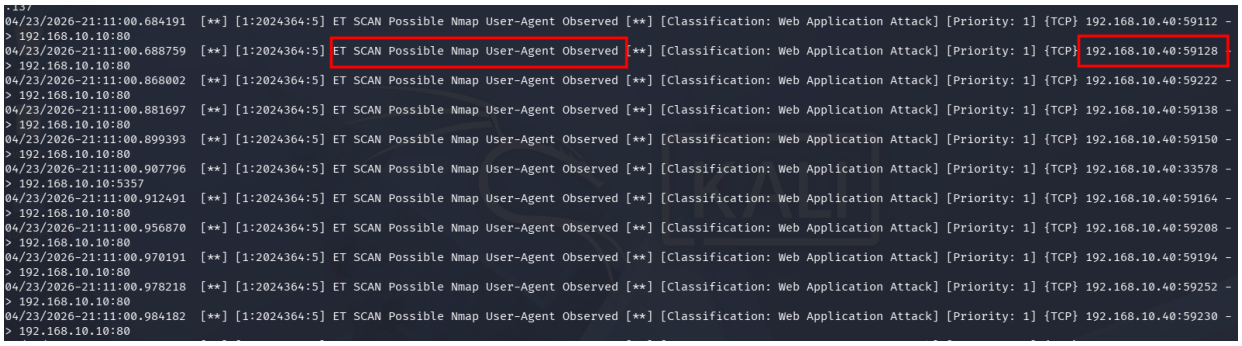


```
05/03/2026-04:08:50.213785  [**] [1:9000032:1] Brute Force - SMB Authentication [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.10.40:60348 -> 192.168.10.10:445
05/03/2026-04:08:50.228154  [**] [1:9000033:1] SMB Brute Force Detected [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.10.40:60392 -> 192.168.10.10:445
05/03/2026-04:08:50.228154  [**] [1:9000032:1] Brute Force - SMB Authentication [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.10.40:60392 -> 192.168.10.10:445
05/03/2026-04:08:50.336723  [**] [1:9000002:1] TCP Port Scan Detected [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.10.40:53518 -> 192.168.10.10:464
05/03/2026-04:09:14.992332  [**] [1:9000031:1] Brute Force - SSH Login Attempts [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.10.40:34403 -> 192.168.10.10:22
05/03/2026-04:09:17.363418  [**] [1:9000031:1] Brute Force - SSH Login Attempts [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.10.40:34659 -> 192.168.10.10:22
05/03/2026-04:09:18.188272  [**] [1:9000002:1] TCP Port Scan Detected [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.10.40:38088 -> 192.168.10.10:80
05/03/2026-04:09:18.393029  [**] [1:9000042:1] NBT-NS Query Detected - Possible Poisoning [**] [Classification: (null)] [Priority: 3] {UDP} 192.168.10.40:56691 -> 192.168.10.10:137
05/03/2026-04:09:18.396227  [**] [1:9000042:1] NBT-NS Query Detected - Possible Poisoning [**] [Classification: (null)] [Priority: 3] {UDP} 192.168.10.40:51092 -> 192.168.10.10:137
05/03/2026-04:09:19.552016  [**] [1:9000042:1] NBT-NS Query Detected - Possible Poisoning [**] [Classification: (null)] [Priority: 3] {UDP} 192.168.10.40:49045 -> 192.168.10.10:137
05/03/2026-04:09:19.606608  [**] [1:9000042:1] NBT-NS Query Detected - Possible Poisoning [**] [Classification: (null)] [Priority: 3] {UDP} 192.168.10.40:35743 -> 192.168.10.10:137
05/03/2026-04:09:20.715491  [**] [1:9000042:1] NBT-NS Query Detected - Possible Poisoning [**] [Classification: (null)] [Priority: 3] {UDP} 192.168.10.40:53801 -> 192.168.10.10:137
05/03/2026-04:09:20.763221  [**] [1:9000042:1] NBT-NS Query Detected - Possible Poisoning [**] [Classification: (null)] [Priority: 3] {UDP} 192.168.10.40:48311 -> 192.168.10.10:137
05/03/2026-04:09:21.655935  [**] [1:9000031:1] Brute Force - SSH Login Attempts [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.10.40:48756 -> 192.168.10.10:22
```

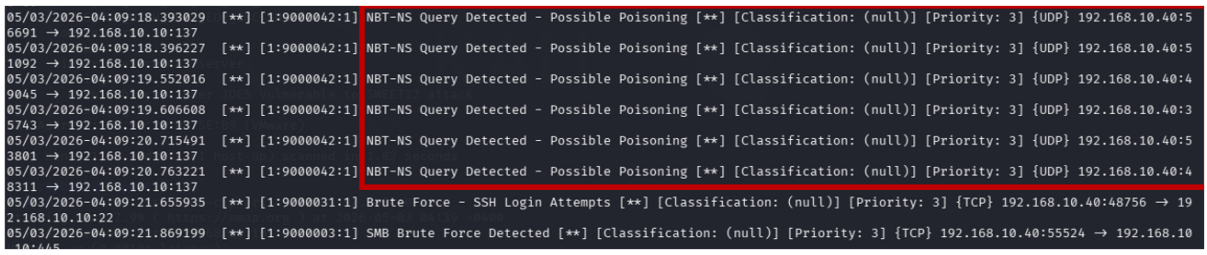
TCP Port Scan



ET Scan



NBT-NS Query



Conclusion

Module 4 adds the perimeter security layer that completes the three-module lab series. With pfSense as the central gateway, traffic policies are enforced at the network level rather than relying solely on host-based controls. The attack simulation confirms that each security layer works as intended — the firewall blocks restricted traffic, the IDS detects application-layer attacks, the account lockout policy stops brute force, and LLMNR poisoning fails due to the GPO applied in Module 3. Together, Modules 2, 3, and 4 demonstrate a practical implementation of defence in depth across administrative, technical, and perimeter security controls.